GRC Risk Assessment Deliverable – Mock Client Engagement | April 2026 | GRC Consulting Firm

Full name: SAMUEL ADEOLUWA OKUNRIBIDO

Date: 13/04/2026

Executive Summary

This lab exercise involved a full GRC-focused vulnerability assessment of the Metasploitable 2 target system (IP: 192.168.43.225). Using industry-standard tools, critical vulnerabilities were identified, including a known backdoor in vsFTPd (CVE-2011-2523), weak/default credentials, unencrypted services (Telnet/FTP), and severely outdated web components (Apache 2.2.8 and PHP 5.2.4).

Quantitative risk analysis showed a combined Annualized Loss Expectancy (ALE) of ₦192.35 million. The findings demonstrate a significantly expanded attack surface and non-compliance with key frameworks such as CIS Controls, NIST CSF, and NIST SP 800-53.

The lab successfully progressed from technical scanning (Phase 1–2) to business-focused risk assessment and treatment (Phase 3–5), highlighting the importance of translating technical findings into actionable GRC decisions for management.

Lab Objectives

Upon completion of this lab, you will be able to:

- Execute Technical Scans: Use Nmap, Nikto, and Nuclei to discover services and vulnerabilities.
- Analyze Technical Output: Interpret scan results to identify specific service versions and security weaknesses.
- Conduct Risk Triage: Map technical vulnerabilities to risk levels (Low, Medium, High) and business impact.
- Align with Frameworks: Connect findings to industry standards like CIS Controls, NIST CSF, and PCI DSS.
- Draft Executive Reports: Communicate technical risks to management using non-technical, business-focused language.
- Quantify Risk: Perform quantitative risk analysis (SLE, ALE) to assess financial impact.
- Develop Risk Treatment Plans: Formulate strategies to Mitigate, Transfer, Accept, or Avoid identified risks.
- Map Controls: Align technical vulnerabilities with relevant security controls (e.g., NIST 800-53).
- Integrate BIA: Understand and articulate the business impact of technical failures.

Tools and Resources Used

- Operating Systems: Kali Linux (Attacker), Metasploitable 2 (Target)
- Scanning Tools:
- Nmap (with -sV –sA -sO for service/version detection and scripting)

- Nikto (web server vulnerability scanner)
- Nuclei (template-based vulnerability scanner)
- Reporting Tools: xsltproc (for Nmap HTML report)
- Frameworks Referenced:
- CIS Controls v8
- NIST Cybersecurity Framework (CSF) 2.0
- NIST SP 800-53
- Virtualization: Oracle VirtualBox with Bridged Adapter

Analysis and Findings

Phase 1 – Information Gathering & Service Discovery Nmap scan revealed multiple legacy services running with known vulnerabilities:

- FTP (vsFTPd 2.3.4 – backdoor present)
- SSH, Telnet, Samba, Unreal IRCd, and several web services

Phase 2 – Vulnerability Identification

- Nikto scan confirmed outdated Apache 2.2.8, PHP 5.2.4, exposed phpMyAdmin, directory indexing, and missing security headers.
- Nuclei scan (after template update) further validated high-severity issues.

Phase 3–5 – Risk Assessment & Business Impact Top critical risks were quantified:

- vsFTPd Backdoor: ALE ₦64 million
- Weak/Default Credentials: ALE ₦48.6 million
- Unencrypted Services & Outdated Web Stack: Combined ALE over ₦79 million

These risks directly violate CIS Controls 5.2, 7.1 and NIST CSF categories PR.AC-1, PR.DS-2, and PR.IP-1.

Main Challenges

Nuclei templates were initially missing/outdated, requiring multiple reset and update attempts (nuclei -reset + nuclei -update-templates).
Metasploitable VM network configuration initially used broadcast IP; corrected to real host IP (192.168.43.225).
Converting and attaching the .vmdk disk file in VirtualBox required creating a .vdi clone.
Translating raw technical scan output into business language and quantitative risk metrics (SLE/ALE).

Conclusion

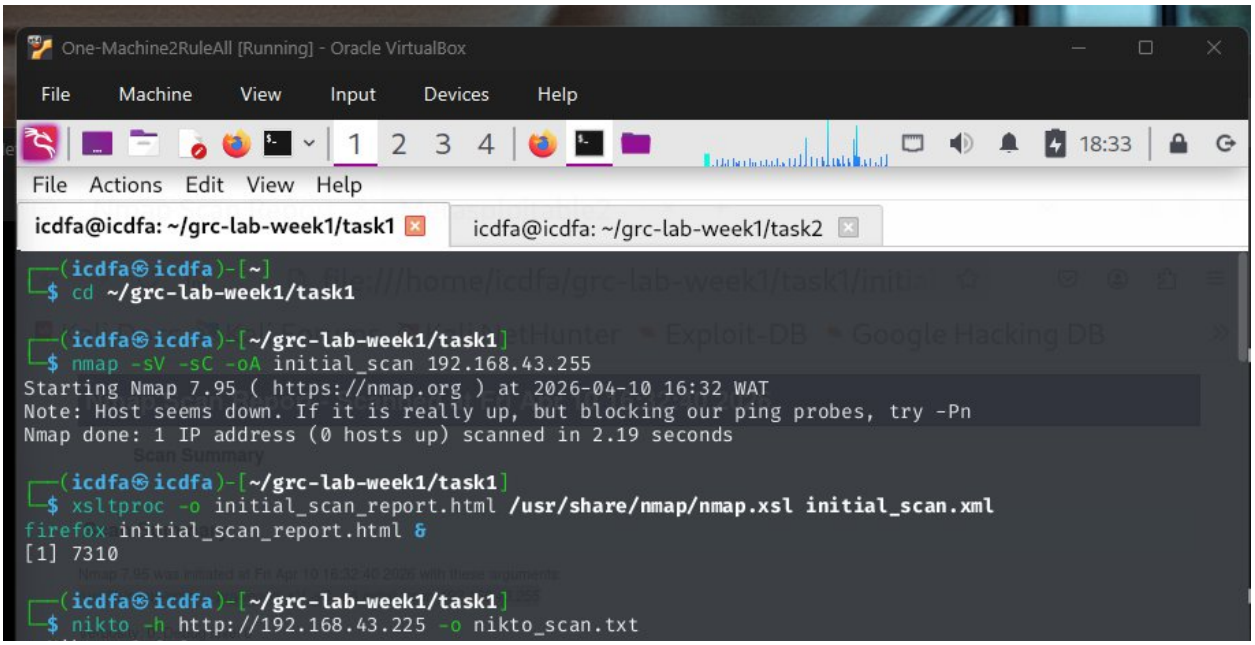
This lab demonstrated the full GRC lifecycle: from technical discovery (Nmap, Nikto, Nuclei) to risk quantification and executive communication. The Metasploitable system represents a classic example of a high-risk development/test environment that, if left unaddressed in a real organization, would lead to significant financial loss, regulatory non-compliance, and reputational damage.

The exercise reinforced that effective GRC is not only about running scans but about interpreting results and providing clear, business-focused recommendations.

Recommendations

- Immediately isolate the server from the production network.
- Disable or patch vsFTPd, Telnet, and other unnecessary services.
- Enforce strong authentication and remove default credentials.
- Upgrade or decommission outdated web components (Apache/PHP).
- Implement regular automated vulnerability scanning and baseline configuration reviews for all test/development systems.
- Integrate findings into the organization's risk register with assigned owners and timelines.

Phase 1 Deliverable: Information Gathering & Service Discovery



GRC Reflection Question Answer

Why is knowing which ports are open (e.g., 21/FTP, 23/Telnet) a compliance issue?

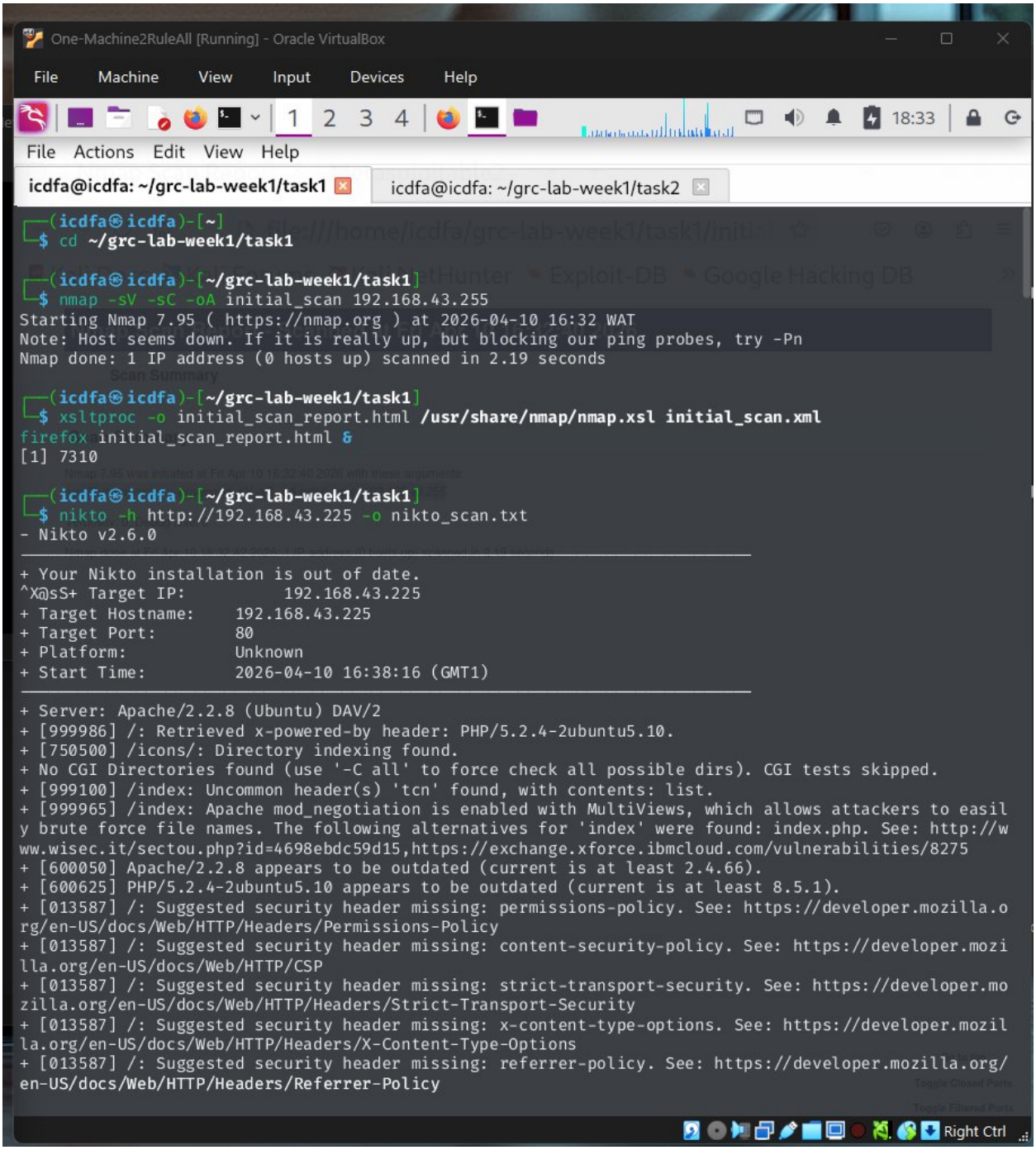
Knowing which ports are open is a critical compliance issue because every unnecessary open port significantly expands the **attack surface** of the organization.

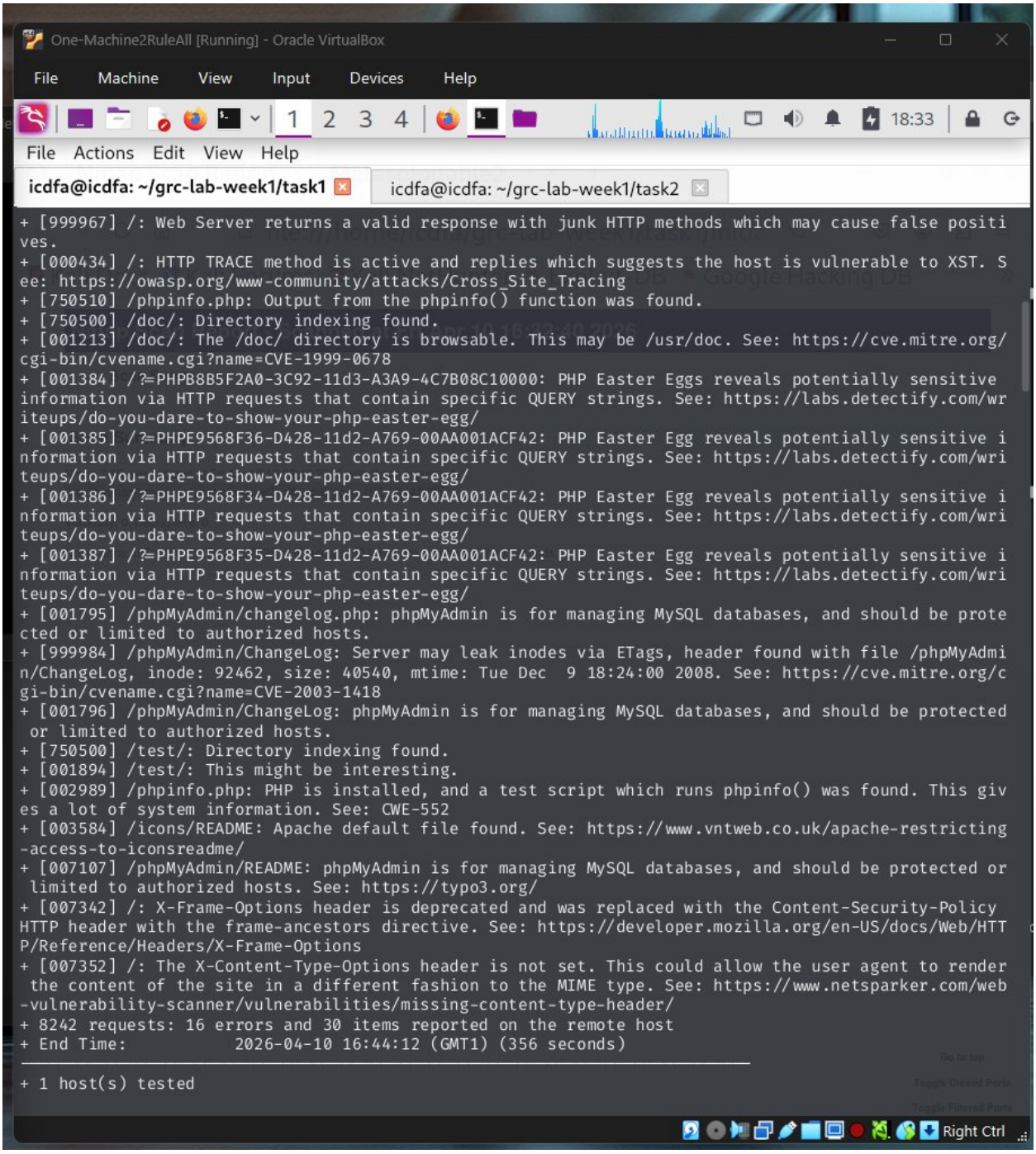
- Services like FTP (port 21) and Telnet (port 23) are legacy protocols that transmit data (including usernames and passwords) in **clear text**, violating basic confidentiality requirements.
- They are rarely needed for business operations today, yet they remain enabled by default on many systems.
- This directly contravenes key controls such as:
    - **CIS Control 9 (Inventory and Control of Applications)** – Only authorized software and services should be running.
    - **NIST CSF PR.IP-1** – Baselines should be established and maintained for systems.

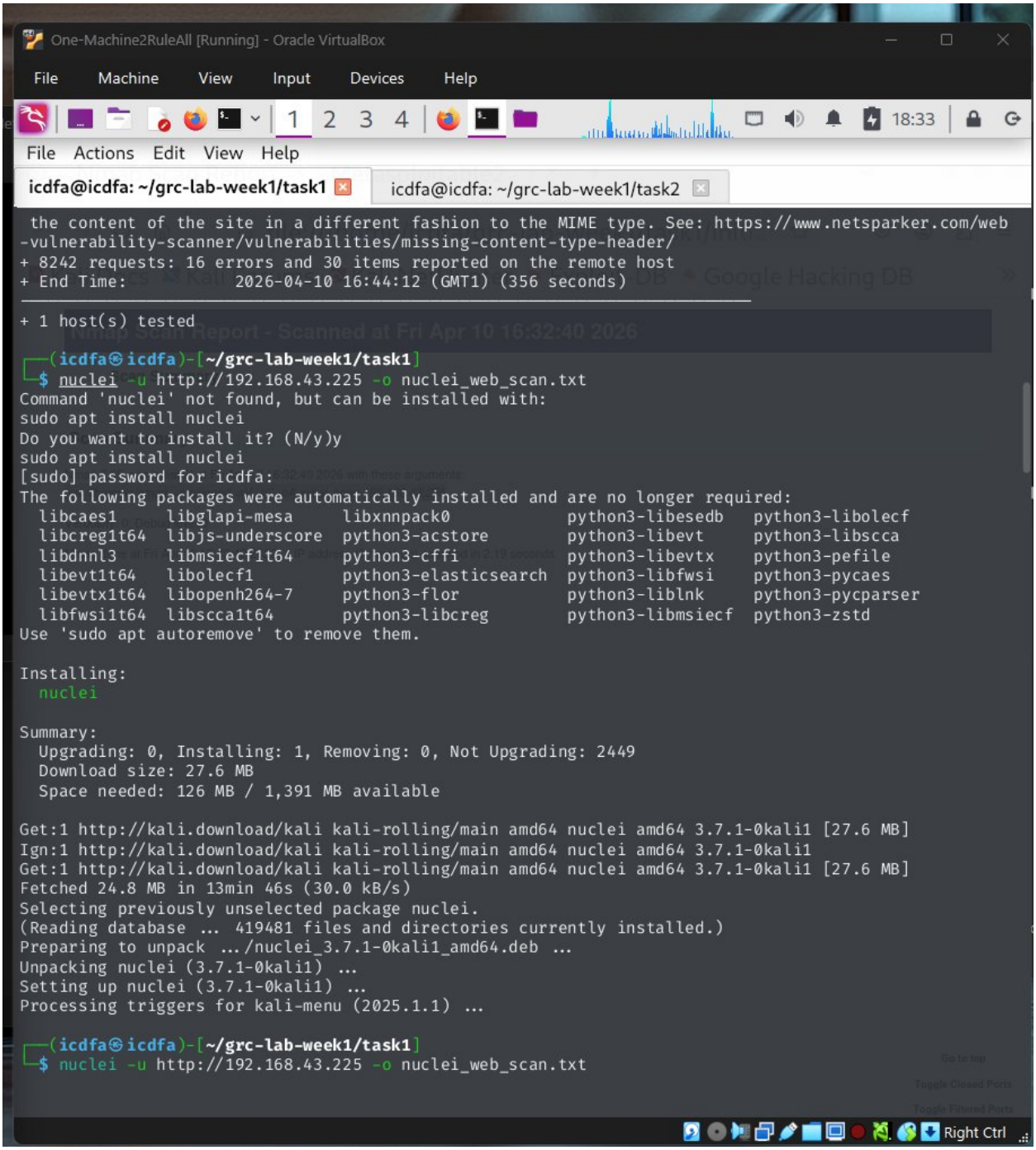
From a GRC perspective, open unnecessary ports increase regulatory risk (NDPR, ISO 27001, PCI-DSS), make audits more difficult, and raise the likelihood of successful attacks, which can lead to data breaches, fines, and loss of compliance certifications.

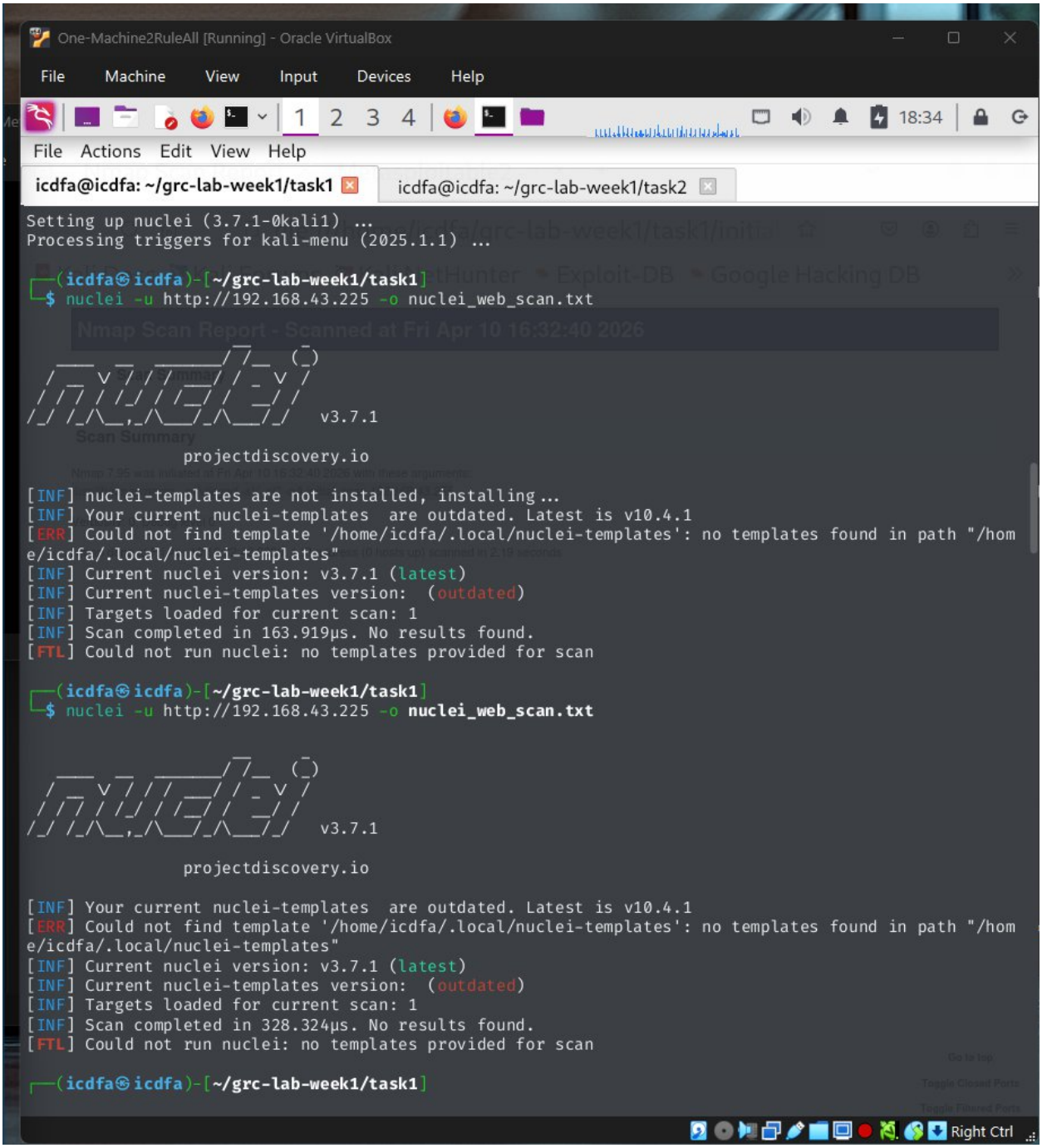
In simple terms: Identifying and disabling unnecessary ports is a fundamental part of **attack surface reduction** and **secure configuration management** and both core requirements in any effective GRC program.

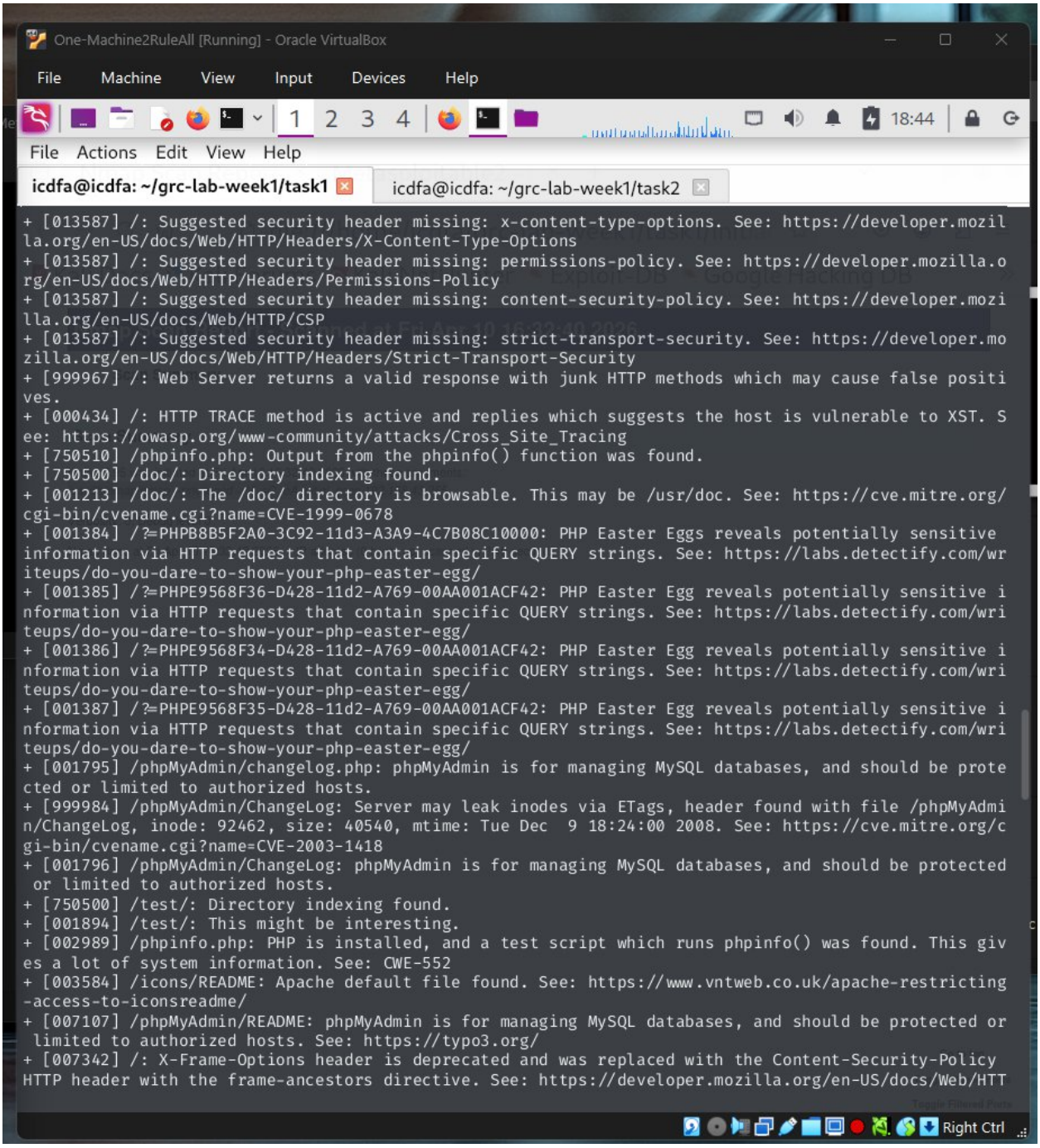
Phase 2: Vulnerability Identification

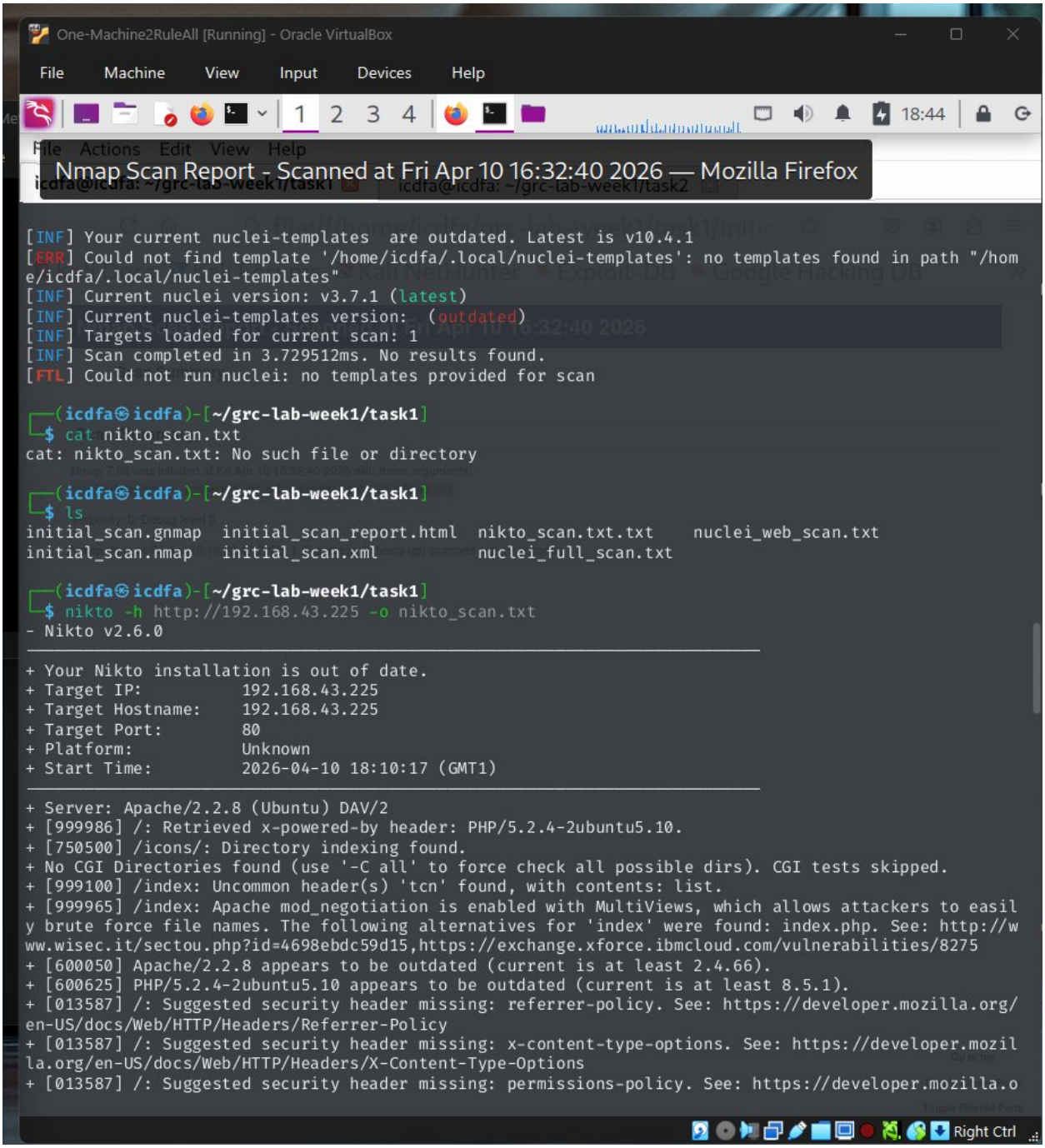


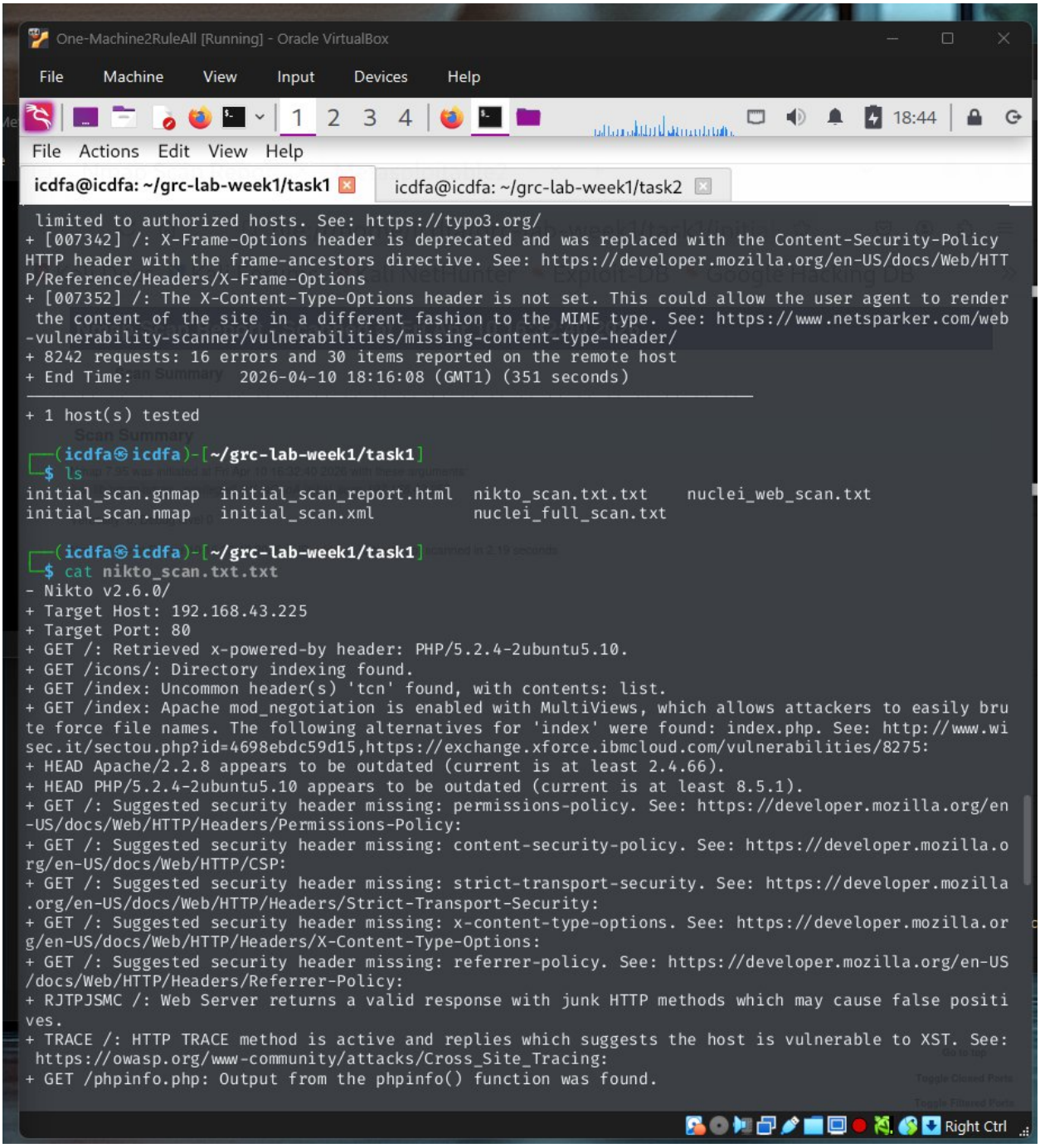

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
18:33
File Actions Edit View Help
icdfa@icdfa: ~/grc-lab-week1/task1
icdfa@icdfa: ~/grc-lab-week1/task2
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 18:24:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8242 requests: 16 errors and 30 items reported on the remote host
+ End Time: 2026-04-10 16:44:12 (GMT1) (356 seconds)
+ 1 host(s) tested
Right Ctrl

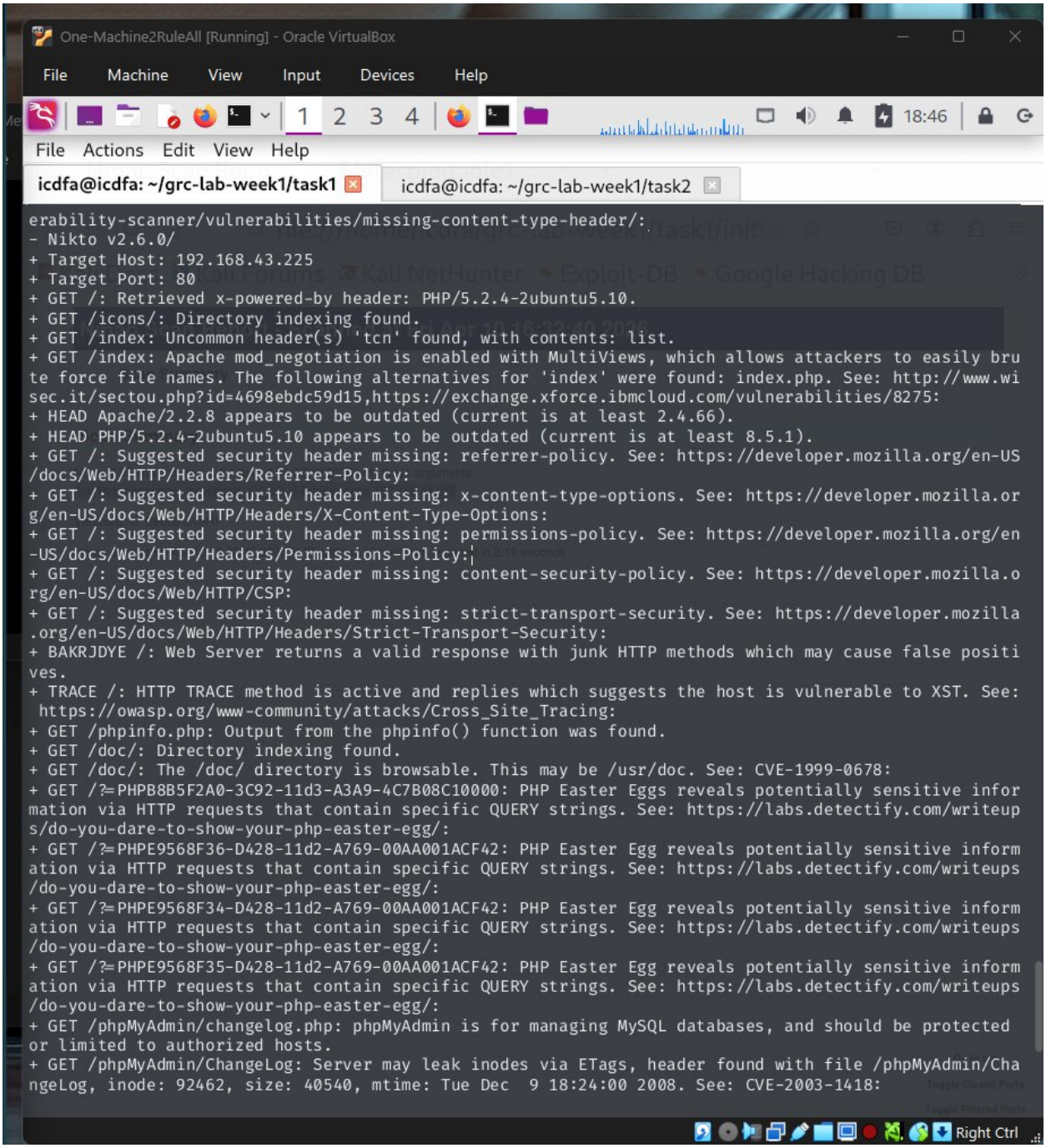

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
18:33
File Actions Edit View Help
icdfa@icdfa: ~/grc-lab-week1/task1
icdfa@icdfa: ~/grc-lab-week1/task2
the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8242 requests: 16 errors and 30 items reported on the remote host
+ End Time: 2026-04-10 16:44:12 (GMT1) (356 seconds)
+ 1 host(s) tested
┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ nuclei -u http://192.168.43.225 -o nuclei_web_scan.txt
Command 'nuclei' not found, but can be installed with:
sudo apt install nuclei
Do you want to install it? (N/y)y
sudo apt install nuclei
[sudo] password for icdfa:
The following packages were automatically installed and are no longer required:
libcaes1 libglapi-mesa libxnnpack0 python3-libesedb python3-libolecf
libcreg1t64 libjs-underscore python3-acstore python3-libevt python3-libscca
libdnnl3 libmsiecf1t64 python3-cffi python3-libevtx python3-pefile
libevt1t64 libolecf1 python3-elasticsearch python3-libfwsi python3-pycaes
libevtx1t64 libopenh264-7 python3-flor python3-liblnk python3-pycparser
libfwsi1t64 libscca1t64 python3-libcreg python3-libmsiecf python3-zstd
Use 'sudo apt autoremove' to remove them.
Installing:
nuclei
Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2449
Download size: 27.6 MB
Space needed: 126 MB / 1,391 MB available
Get:1 http://kali.download/kali kali-rolling/main amd64 nuclei amd64 3.7.1-0kali1 [27.6 MB]
Ign:1 http://kali.download/kali kali-rolling/main amd64 nuclei amd64 3.7.1-0kali1
Get:1 http://kali.download/kali kali-rolling/main amd64 nuclei amd64 3.7.1-0kali1 [27.6 MB]
Fetched 24.8 MB in 13min 46s (30.0 kB/s)
Selecting previously unselected package nuclei.
(Reading database ... 419481 files and directories currently installed.)
Preparing to unpack .../nuclei_3.7.1-0kali1_amd64.deb ...
Unpacking nuclei (3.7.1-0kali1) ...
Setting up nuclei (3.7.1-0kali1) ...
Processing triggers for kali-menu (2025.1.1) ...
┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ nuclei -u http://192.168.43.225 -o nuclei_web_scan.txt
Right Ctrl

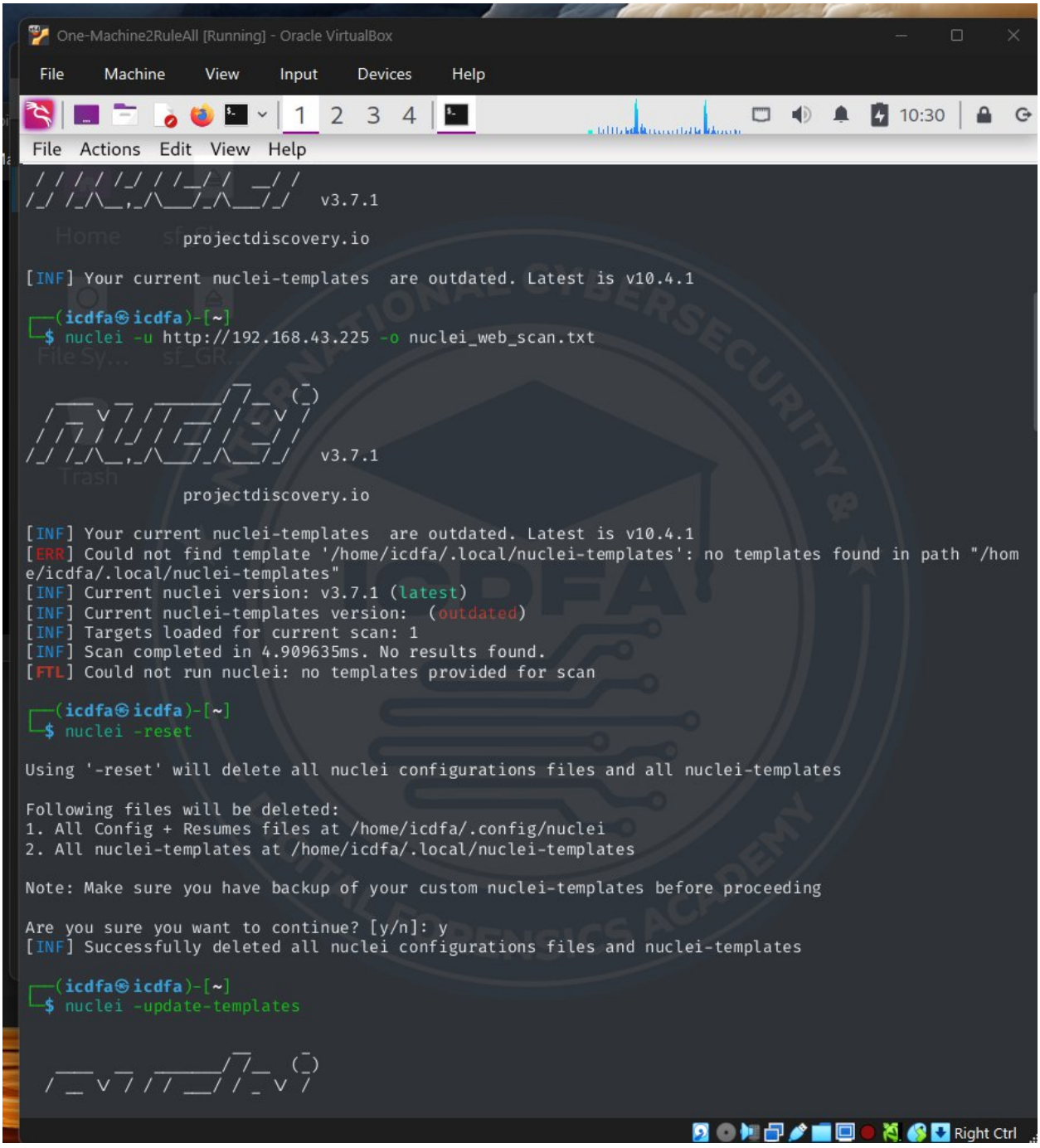

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
File Actions Edit View Help
icdfa@icdfa: ~/grc-lab-week1/task1
icdfa@icdfa: ~/grc-lab-week1/task2
Setting up nuclei (3.7.1-0kali1) ...
Processing triggers for kali-menu (2025.1.1) ...
┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ nuclei -u http://192.168.43.225 -o nuclei_web_scan.txt
v3.7.1
projectdiscovery.io
[INF] nuclei-templates are not installed, installing...
[INF] Your current nuclei-templates are outdated. Latest is v10.4.1
[ERR] Could not find template '/home/icdfa/.local/nuclei-templates': no templates found in path "/home/icdfa/.local/nuclei-templates"
[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: (outdated)
[INF] Targets loaded for current scan: 1
[INF] Scan completed in 163.919µs. No results found.
[FTL] Could not run nuclei: no templates provided for scan
┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ nuclei -u http://192.168.43.225 -o nuclei_web_scan.txt
v3.7.1
projectdiscovery.io
[INF] Your current nuclei-templates are outdated. Latest is v10.4.1
[ERR] Could not find template '/home/icdfa/.local/nuclei-templates': no templates found in path "/home/icdfa/.local/nuclei-templates"
[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: (outdated)
[INF] Targets loaded for current scan: 1
[INF] Scan completed in 328.324µs. No results found.
[FTL] Could not run nuclei: no templates provided for scan
┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
Right Ctrl

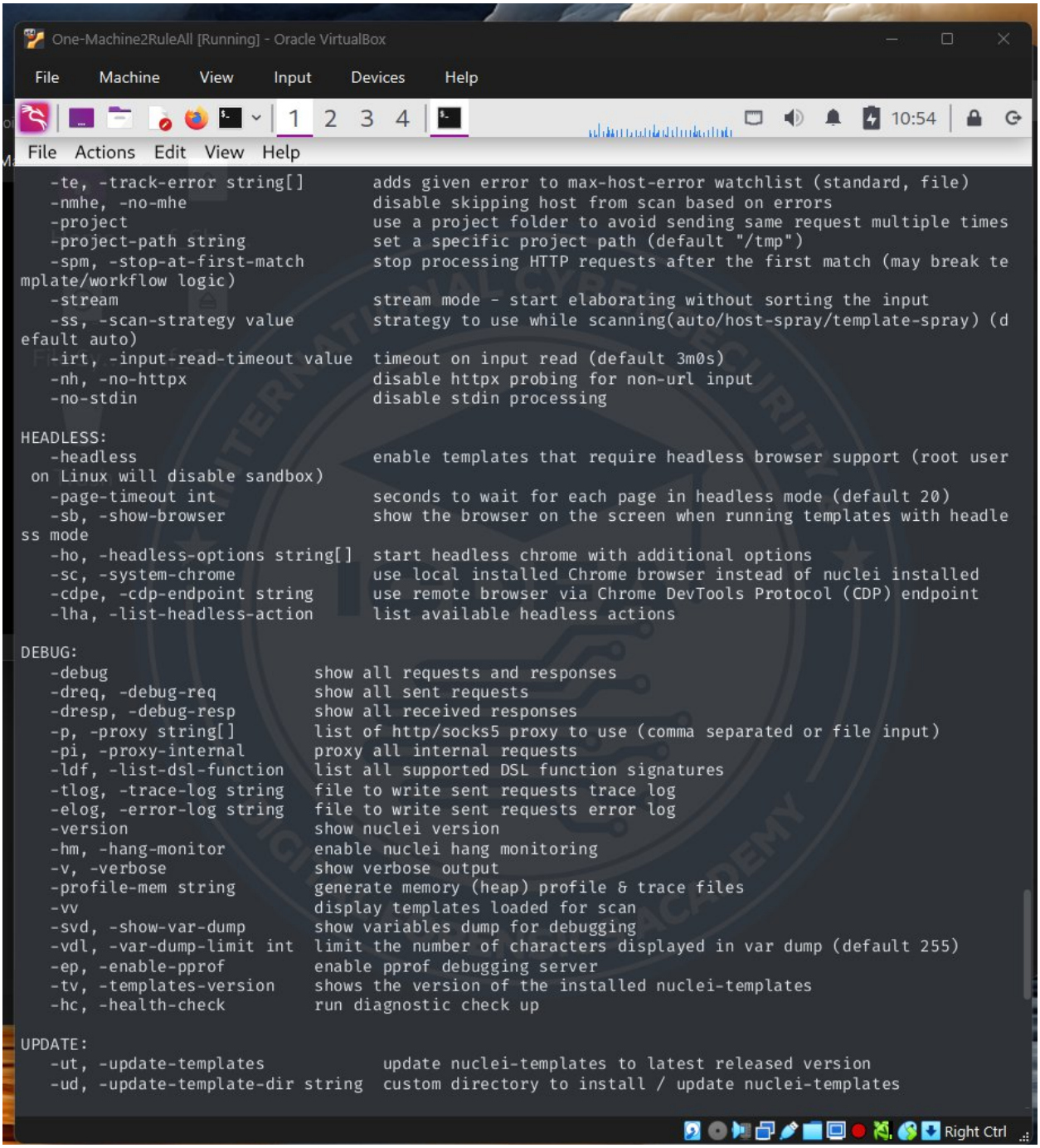

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
18:44
File Actions Edit View Help
icdfa@icdfa: ~/grc-lab-week1/task1
icdfa@icdfa: ~/grc-lab-week1/task2
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 18:24:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTT
Right Ctrl

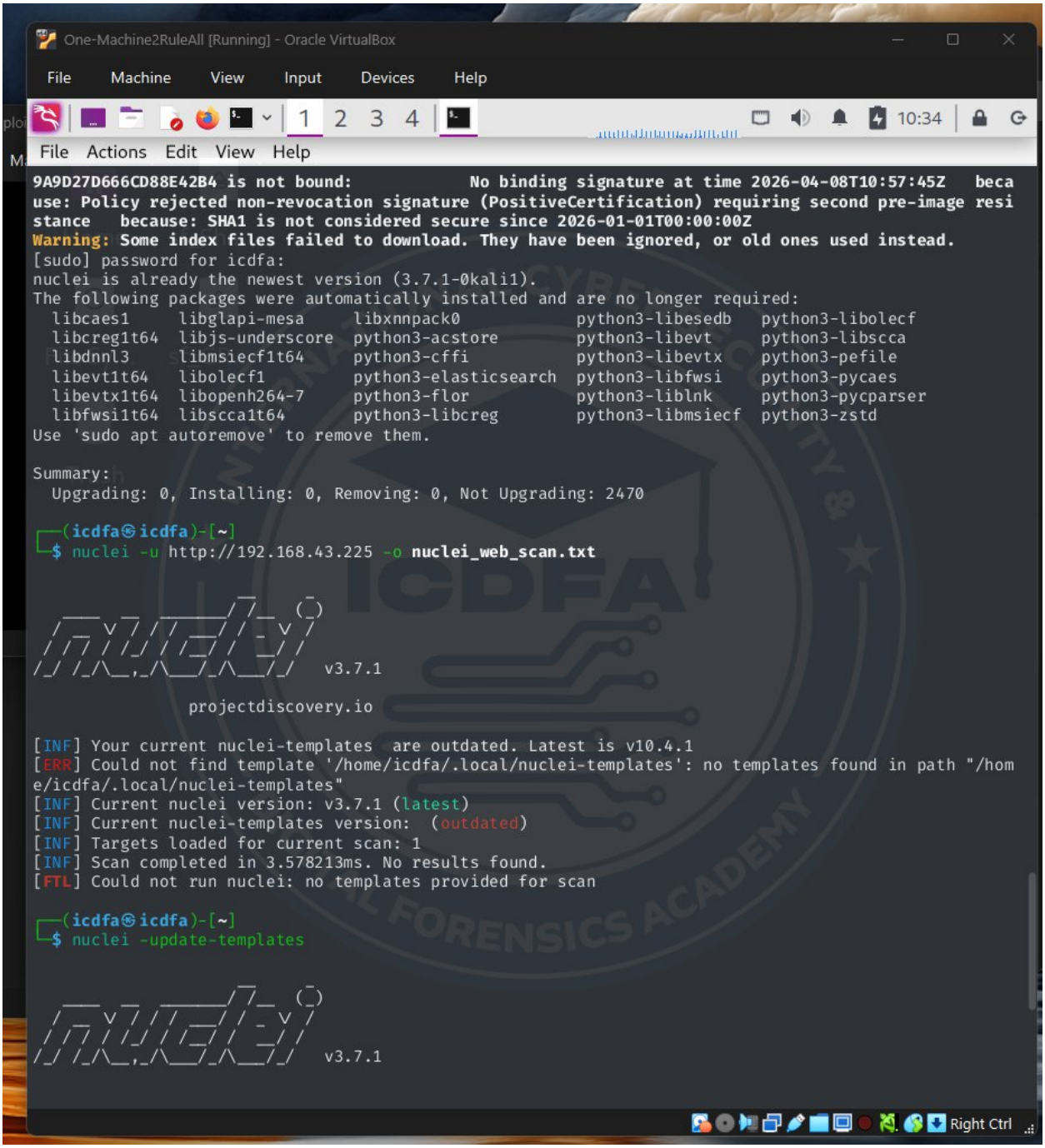

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Nmap Scan Report - Scanned at Fri Apr 10 16:32:40 2026 — Mozilla Firefox
[INF] Your current nuclei-templates are outdated. Latest is v10.4.1
[ERR] Could not find template '/home/icdfa/.local/nuclei-templates': no templates found in path "/home/icdfa/.local/nuclei-templates"
[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: (outdated)
[INF] Targets loaded for current scan: 1
[INF] Scan completed in 3.729512ms. No results found.
[FTL] Could not run nuclei: no templates provided for scan
┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ cat nikto_scan.txt
cat: nikto_scan.txt: No such file or directory
┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ ls
initial_scan.gnmap initial_scan_report.html nikto_scan.txt.txt nuclei_web_scan.txt
initial_scan.nmap initial_scan.xml nuclei_full_scan.txt
┌──(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
└─$ nikto -h http://192.168.43.225 -o nikto_scan.txt
- Nikto v2.6.0
+ Your Nikto installation is out of date.
+ Target IP: 192.168.43.225
+ Target Hostname: 192.168.43.225
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-04-10 18:10:17 (GMT1)
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.o
Right Ctrl

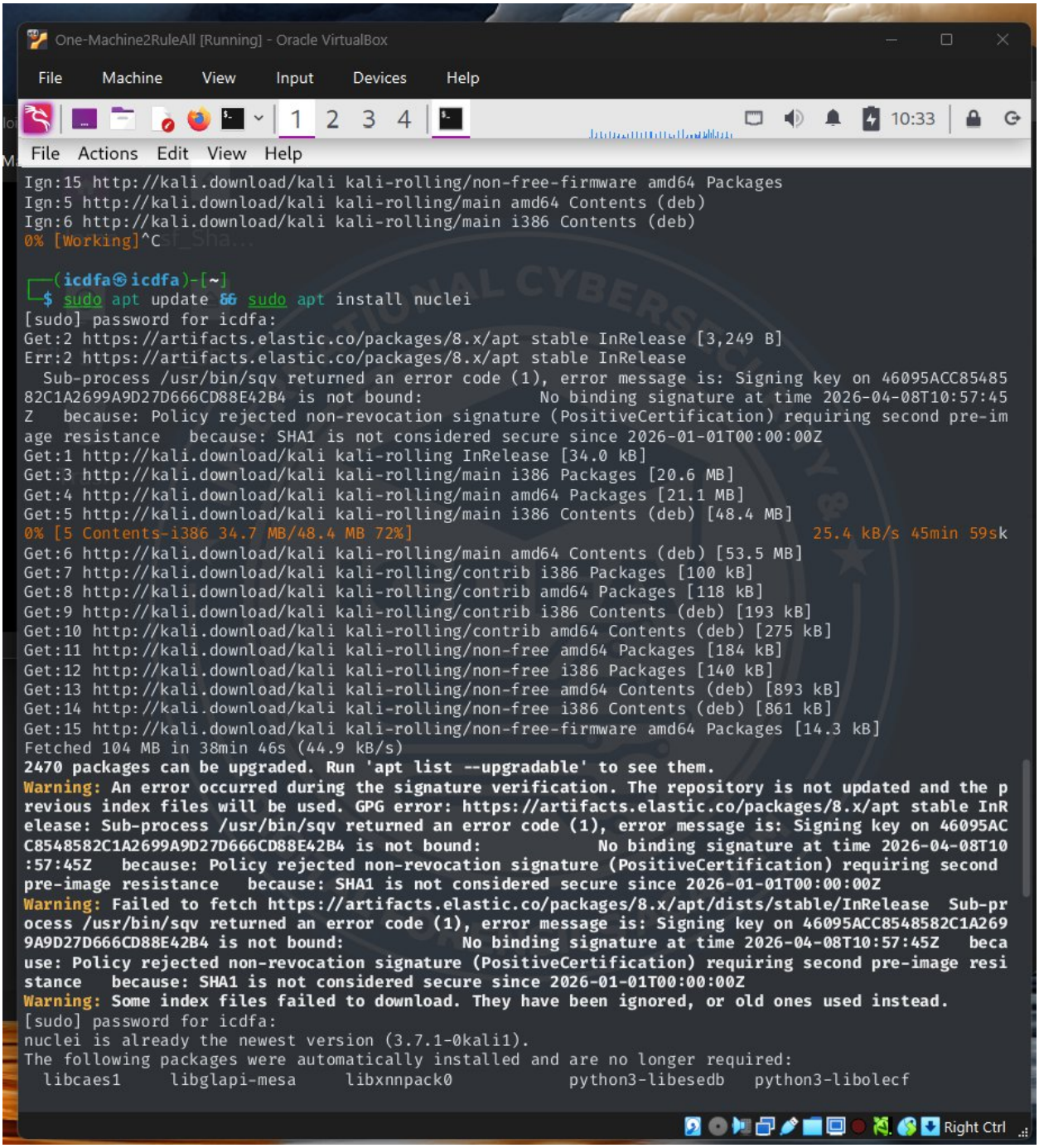

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
File Actions Edit View Help
icdfa@icdfa: ~/grc-lab-week1/task1
icdfa@icdfa: ~/grc-lab-week1/task2
limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8242 requests: 16 errors and 30 items reported on the remote host
+ End Time: 2026-04-10 18:16:08 (GMT1) (351 seconds)
+ 1 host(s) tested
(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
$ ls
initial_scan.gnmap initial_scan_report.html nikto_scan.txt.txt nuclei_web_scan.txt
initial_scan.nmap initial_scan.xml nuclei_full_scan.txt
(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
$ cat nikto_scan.txt.txt
- Nikto v2.6.0/
+ Target Host: 192.168.43.225
+ Target Port: 80
+ GET /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ GET /icons/: Directory indexing found.
+ GET /index: Uncommon header(s) 'tcn' found, with contents: list.
+ GET /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275:
+ HEAD Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ HEAD PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ GET /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy:
+ GET /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP:
+ GET /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security:
+ GET /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options:
+ GET /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy:
+ RJTPJSMC /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ TRACE /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing:
+ GET /phpinfo.php: Output from the phpinfo() function was found.
Right Ctrl

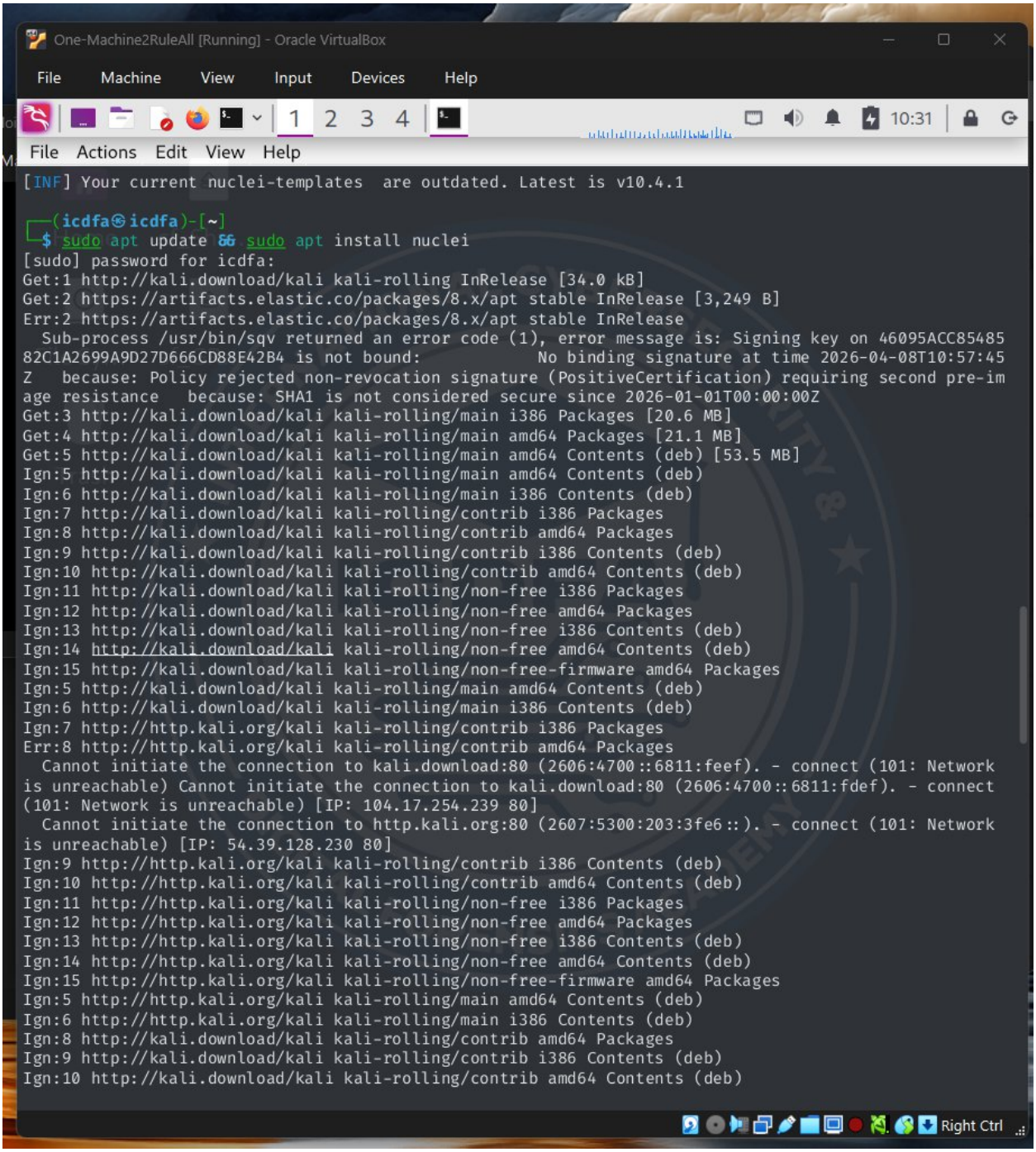

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
18:46
File Actions Edit View Help
icdfa@icdfa: ~/grc-lab-week1/task1
icdfa@icdfa: ~/grc-lab-week1/task2
erability-scanner/vulnerabilities/missing-content-type-header/:
- Nikto v2.6.0/
+ Target Host: 192.168.43.225
+ Target Port: 80
+ GET /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ GET /icons/: Directory indexing found.
+ GET /index: Uncommon header(s) 'tcn' found, with contents: list.
+ GET /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily bru
te force file names. The following alternatives for 'index' were found: index.php. See: http://www.wi
sec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275:
+ HEAD Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ HEAD PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ GET /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US
/docs/Web/HTTP/Headers/Referrer-Policy:
+ GET /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.or
g/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options:
+ GET /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en
-US/docs/Web/HTTP/Headers/Permissions-Policy:
+ GET /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.o
rg/en-US/docs/Web/HTTP/CSP:
+ GET /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla
.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security:
+ BAKRJDYE /: Web Server returns a valid response with junk HTTP methods which may cause false positi
ves.
+ TRACE /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See:
https://owasp.org/www-community/attacks/Cross_Site_Tracing:
+ GET /phpinfo.php: Output from the phpinfo() function was found.
+ GET /doc/: Directory indexing found.
+ GET /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: CVE-1999-0678:
+ GET /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive infor
mation via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeup
s/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive inform
ation via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups
/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive inform
ation via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups
/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive inform
ation via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups
/do-you-dare-to-show-your-php-easter-egg/:
+ GET /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected
or limited to authorized hosts.
+ GET /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/Cha
ngeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 18:24:00 2008. See: CVE-2003-1418:
Right Ctrl

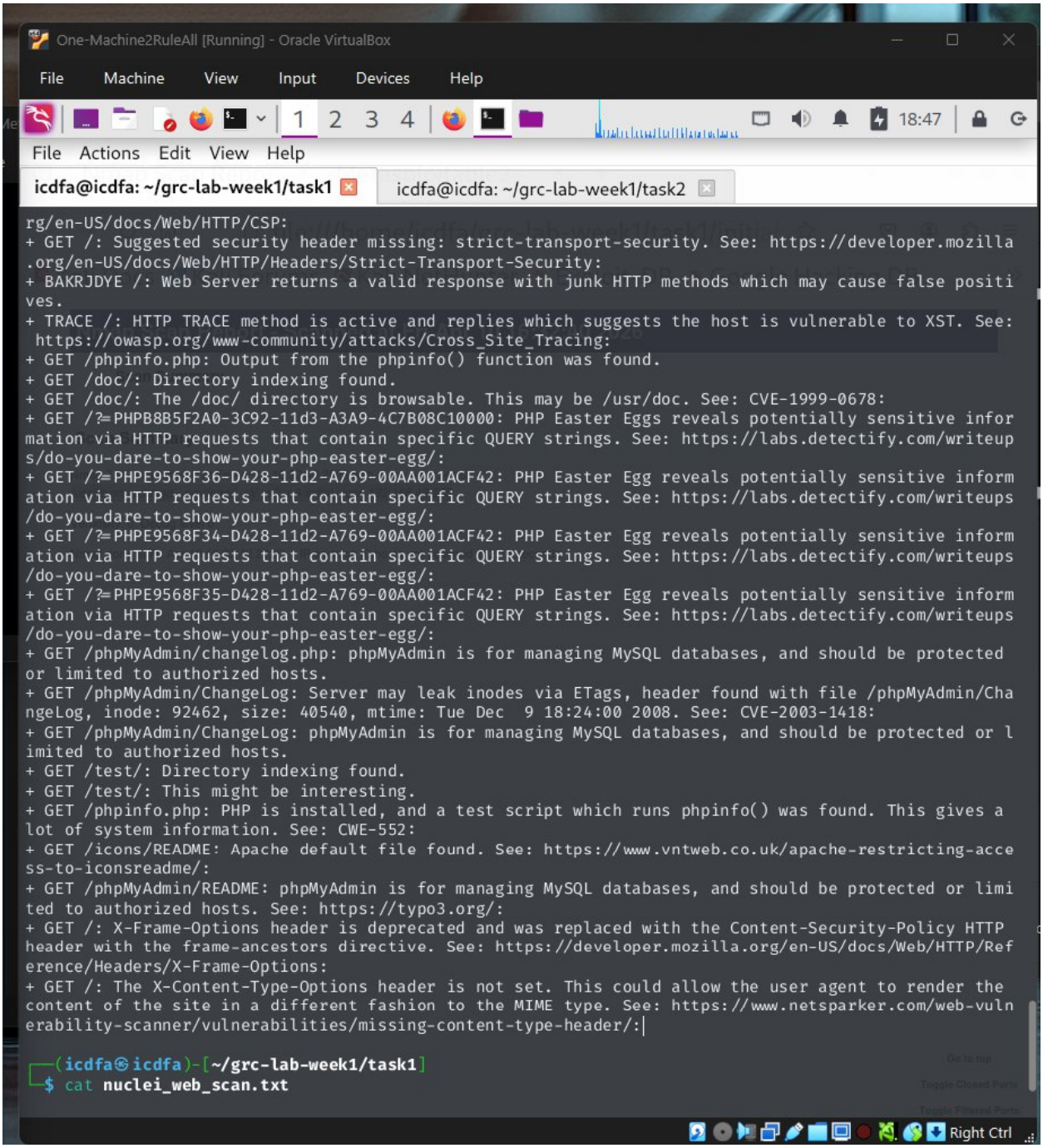

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
File Actions Edit View Help
v3.7.1
projectdiscovery.io
[INF] Your current nuclei-templates are outdated. Latest is v10.4.1
(icdfa㉿icdfa)-[~]
$ nuclei -u http://192.168.43.225 -o nuclei_web_scan.txt
v3.7.1
projectdiscovery.io
[INF] Your current nuclei-templates are outdated. Latest is v10.4.1
[ERR] Could not find template '/home/icdfa/.local/nuclei-templates': no templates found in path "/home/icdfa/.local/nuclei-templates"
[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: (outdated)
[INF] Targets loaded for current scan: 1
[INF] Scan completed in 4.909635ms. No results found.
[FTL] Could not run nuclei: no templates provided for scan
(icdfa㉿icdfa)-[~]
$ nuclei -reset
Using '-reset' will delete all nuclei configurations files and all nuclei-templates
Following files will be deleted:
1. All Config + Resumes files at /home/icdfa/.config/nuclei
2. All nuclei-templates at /home/icdfa/.local/nuclei-templates
Note: Make sure you have backup of your custom nuclei-templates before proceeding
Are you sure you want to continue? [y/n]: y
[INF] Successfully deleted all nuclei configurations files and nuclei-templates
(icdfa㉿icdfa)-[~]
$ nuclei -update-templates
Right Ctrl

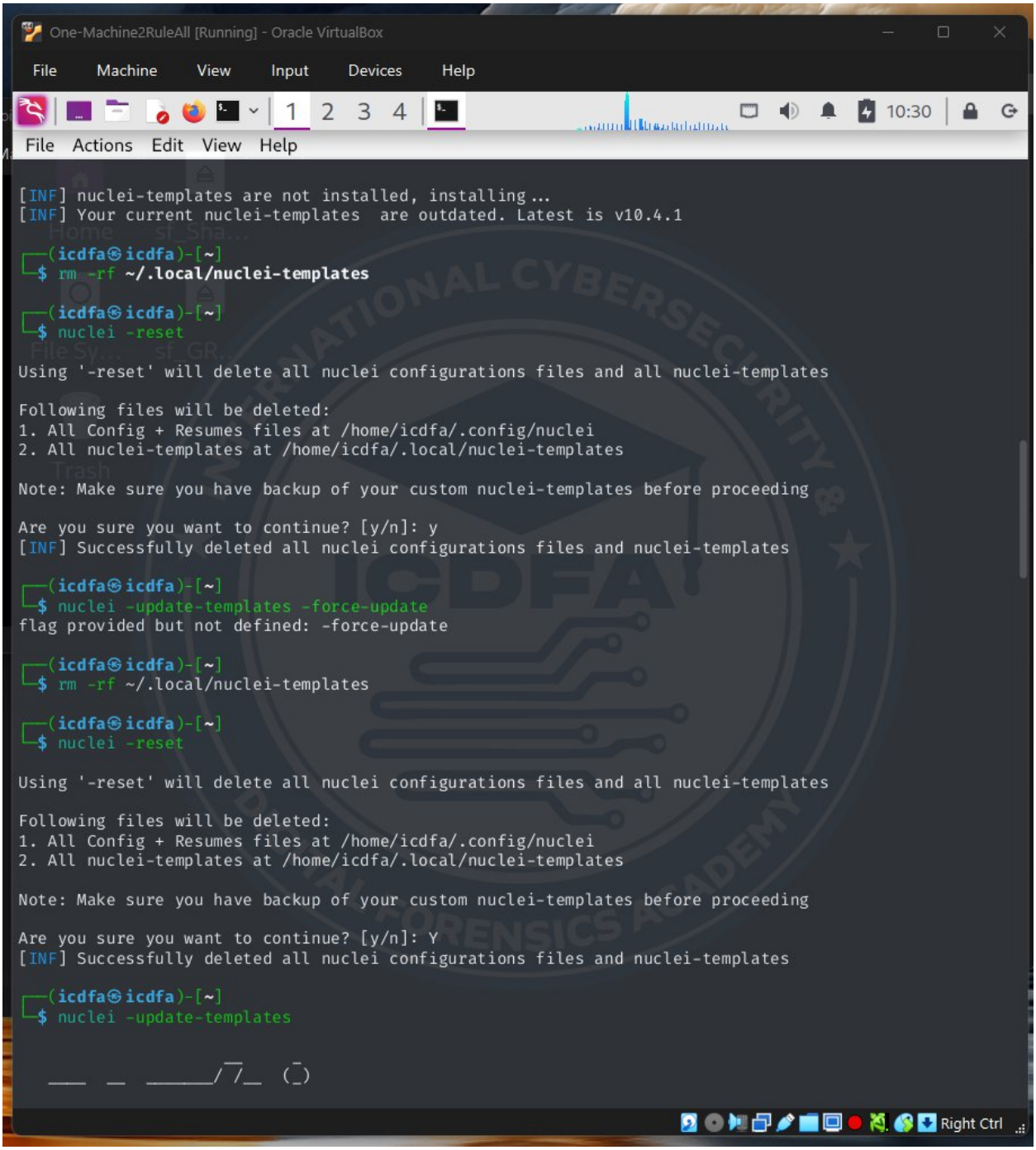

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:54
File Actions Edit View Help
-te, -track-error string[] adds given error to max-host-error watchlist (standard, file)
-nmhe, -no-mhe disable skipping host from scan based on errors
-project use a project folder to avoid sending same request multiple times
-project-path string set a specific project path (default "/tmp")
-spm, -stop-at-first-match stop processing HTTP requests after the first match (may break template/workflow logic)
-stream stream mode - start elaborating without sorting the input
-ss, -scan-strategy value strategy to use while scanning(auto/host-spray/template-spray) (default auto)
-irt, -input-read-timeout value timeout on input read (default 3m0s)
-nh, -no-httpx disable httpx probing for non-url input
-no-stdin disable stdin processing
HEADLESS:
-headless enable templates that require headless browser support (root user on Linux will disable sandbox)
-page-timeout int seconds to wait for each page in headless mode (default 20)
-sb, -show-browser show the browser on the screen when running templates with headless mode
-ho, -headless-options string[] start headless chrome with additional options
-sc, -system-chrome use local installed Chrome browser instead of nuclei installed
-cdpe, -cdp-endpoint string use remote browser via Chrome DevTools Protocol (CDP) endpoint
-lha, -list-headless-action list available headless actions
DEBUG:
-debug show all requests and responses
-dreq, -debug-req show all sent requests
-dresp, -debug-resp show all received responses
-p, -proxy string[] list of http/socks5 proxy to use (comma separated or file input)
-pi, -proxy-internal proxy all internal requests
-ldf, -list-dsl-function list all supported DSL function signatures
-tlog, -trace-log string file to write sent requests trace log
-elog, -error-log string file to write sent requests error log
-version show nuclei version
-hm, -hang-monitor enable nuclei hang monitoring
-v, -verbose show verbose output
-profile-mem string generate memory (heap) profile & trace files
-vv display templates loaded for scan
-svd, -show-var-dump show variables dump for debugging
-vdl, -var-dump-limit int limit the number of characters displayed in var dump (default 255)
-ep, -enable-pprof enable pprof debugging server
-tv, -templates-version shows the version of the installed nuclei-templates
-hc, -health-check run diagnostic check up
UPDATE:
-ut, -update-templates update nuclei-templates to latest released version
-ud, -update-template-dir string custom directory to install / update nuclei-templates
Right Ctrl

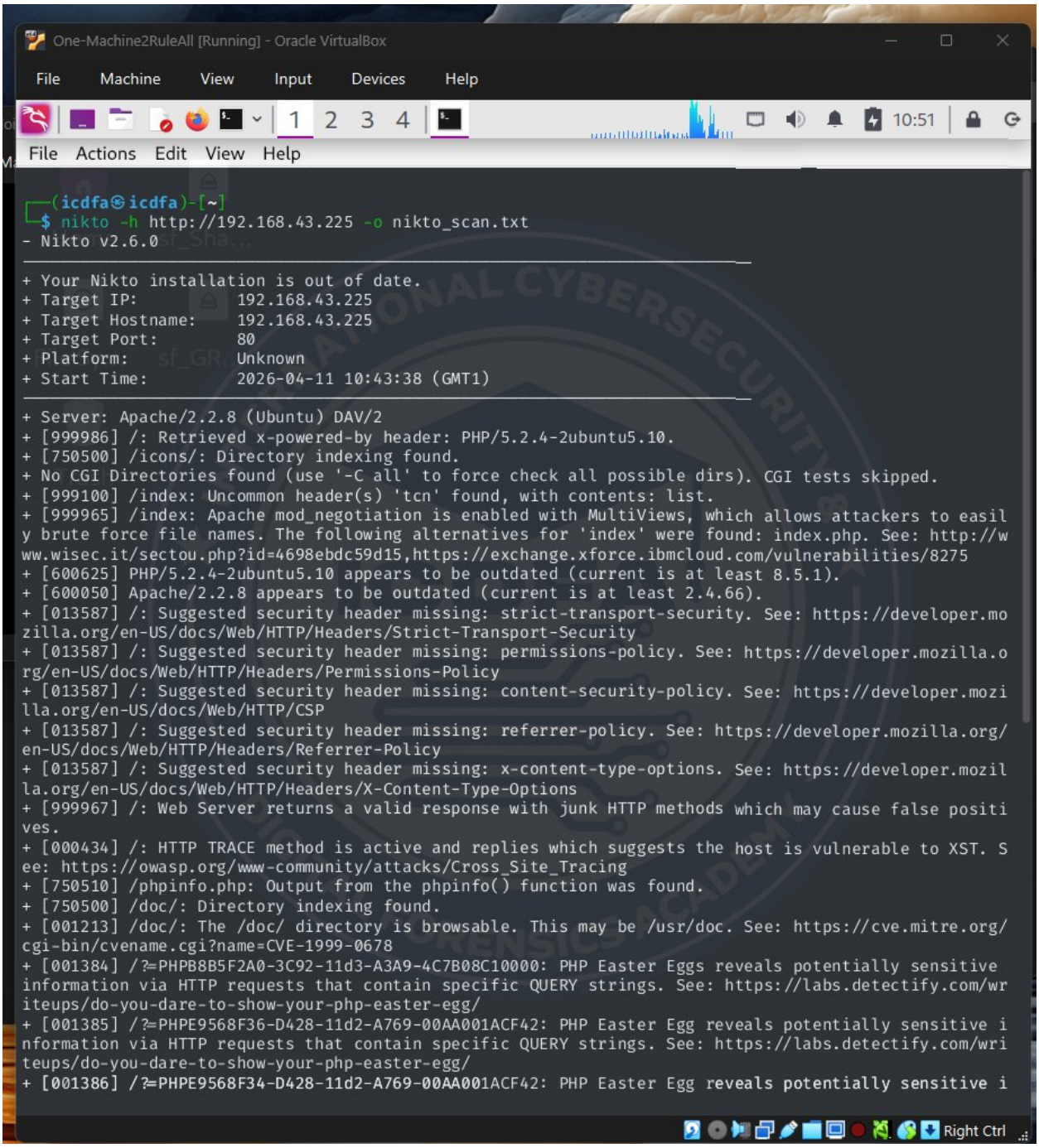

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:34
File Actions Edit View Help
9A9D27D666CD88E42B4 is not bound: No binding signature at time 2026-04-08T10:57:45Z because: Policy rejected non-revocation signature (PositiveCertification) requiring second pre-image resistance because: SHA1 is not considered secure since 2026-01-01T00:00:00Z
Warning: Some index files failed to download. They have been ignored, or old ones used instead.
[sudo] password for icdfa:
nuclei is already the newest version (3.7.1-0kali1).
The following packages were automatically installed and are no longer required:
libcaes1 libglapi-mesa libxnnpack0 python3-libesedb python3-libolecf
libcreg1t64 libjs-underscore python3-acstore python3-libevt python3-libscca
libdnnl3 libmsiecf1t64 python3-cffi python3-libevtx python3-pefile
libevt1t64 libolecf1 python3-elasticsearch python3-libfwsi python3-pycaes
libevtx1t64 libopenh264-7 python3-flor python3-liblnk python3-pycparser
libfwsi1t64 libscca1t64 python3-libcreg python3-libmsiecf python3-zstd
Use 'sudo apt autoremove' to remove them.
Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 2470
(icdfa㉿icdfa)-[~]
$ nuclei -u http://192.168.43.225 -o nuclei_web_scan.txt
v3.7.1
projectdiscovery.io
[INF] Your current nuclei-templates are outdated. Latest is v10.4.1
[ERR] Could not find template '/home/icdfa/.local/nuclei-templates': no templates found in path "/home/icdfa/.local/nuclei-templates"
[INF] Current nuclei version: v3.7.1 (latest)
[INF] Current nuclei-templates version: (outdated)
[INF] Targets loaded for current scan: 1
[INF] Scan completed in 3.578213ms. No results found.
[FTL] Could not run nuclei: no templates provided for scan
(icdfa㉿icdfa)-[~]
$ nuclei -update-templates
v3.7.1
Right Ctrl

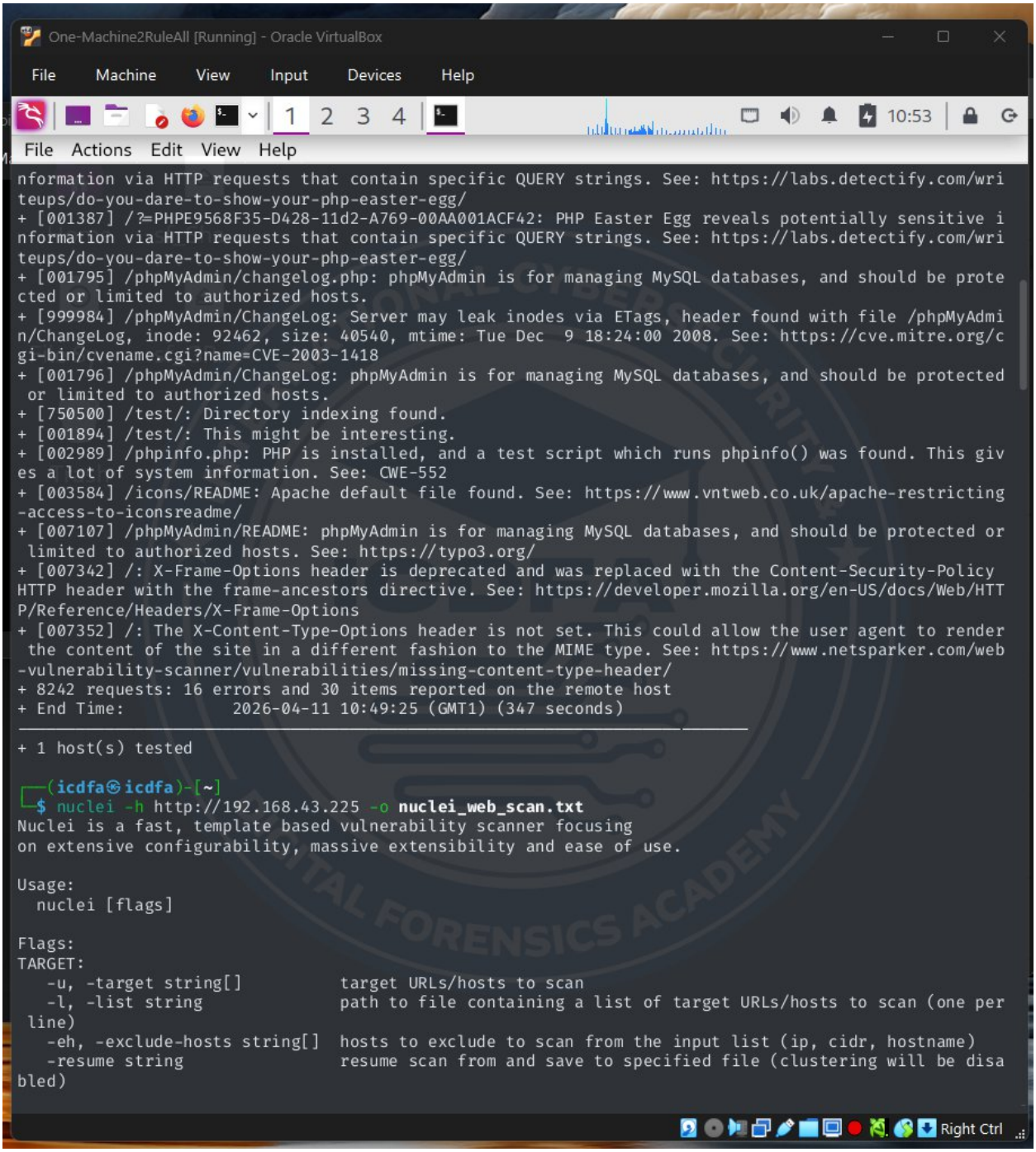

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:33
File Actions Edit View Help
Ign:15 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages
Ign:5 http://kali.download/kali kali-rolling/main amd64 Contents (deb)
Ign:6 http://kali.download/kali kali-rolling/main i386 Contents (deb)
0% [Working]^C
(icdfa㉿icdfa)-[~]
$ sudo apt update && sudo apt install nuclei
[sudo] password for icdfa:
Get:2 https://artifacts.elastic.co/packages/8.x/apt stable InRelease [3,249 B]
Err:2 https://artifacts.elastic.co/packages/8.x/apt stable InRelease
Sub-process /usr/bin/sqv returned an error code (1), error message is: Signing key on 46095ACC8548582C1A2699A9D27D666CD88E42B4 is not bound: No binding signature at time 2026-04-08T10:57:45Z because: Policy rejected non-revocation signature (PositiveCertification) requiring second pre-image resistance because: SHA1 is not considered secure since 2026-01-01T00:00:00Z
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:3 http://kali.download/kali kali-rolling/main i386 Packages [20.6 MB]
Get:4 http://kali.download/kali kali-rolling/main amd64 Packages [21.1 MB]
Get:5 http://kali.download/kali kali-rolling/main i386 Contents (deb) [48.4 MB]
0% [5 Contents-i386 34.7 MB/48.4 MB 72%] 25.4 kB/s 45min 59sk
Get:6 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.5 MB]
Get:7 http://kali.download/kali kali-rolling/contrib i386 Packages [100 kB]
Get:8 http://kali.download/kali kali-rolling/contrib amd64 Packages [118 kB]
Get:9 http://kali.download/kali kali-rolling/contrib i386 Contents (deb) [193 kB]
Get:10 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [275 kB]
Get:11 http://kali.download/kali kali-rolling/non-free amd64 Packages [184 kB]
Get:12 http://kali.download/kali kali-rolling/non-free i386 Packages [140 kB]
Get:13 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [893 kB]
Get:14 http://kali.download/kali kali-rolling/non-free i386 Contents (deb) [861 kB]
Get:15 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [14.3 kB]
Fetched 104 MB in 38min 46s (44.9 kB/s)
2470 packages can be upgraded. Run 'apt list --upgradable' to see them.
Warning: An error occurred during the signature verification. The repository is not updated and the previous index files will be used. GPG error: https://artifacts.elastic.co/packages/8.x/apt stable InRelease: Sub-process /usr/bin/sqv returned an error code (1), error message is: Signing key on 46095ACC8548582C1A2699A9D27D666CD88E42B4 is not bound: No binding signature at time 2026-04-08T10:57:45Z because: Policy rejected non-revocation signature (PositiveCertification) requiring second pre-image resistance because: SHA1 is not considered secure since 2026-01-01T00:00:00Z
Warning: Failed to fetch https://artifacts.elastic.co/packages/8.x/apt/dists/stable/InRelease Sub-process /usr/bin/sqv returned an error code (1), error message is: Signing key on 46095ACC8548582C1A2699A9D27D666CD88E42B4 is not bound: No binding signature at time 2026-04-08T10:57:45Z because: Policy rejected non-revocation signature (PositiveCertification) requiring second pre-image resistance because: SHA1 is not considered secure since 2026-01-01T00:00:00Z
Warning: Some index files failed to download. They have been ignored, or old ones used instead.
[sudo] password for icdfa:
nuclei is already the newest version (3.7.1-0kali1).
The following packages were automatically installed and are no longer required:
libcaes1 libglapi-mesa libxnnpack0 python3-libesedb python3-libolecf
Right Ctrl

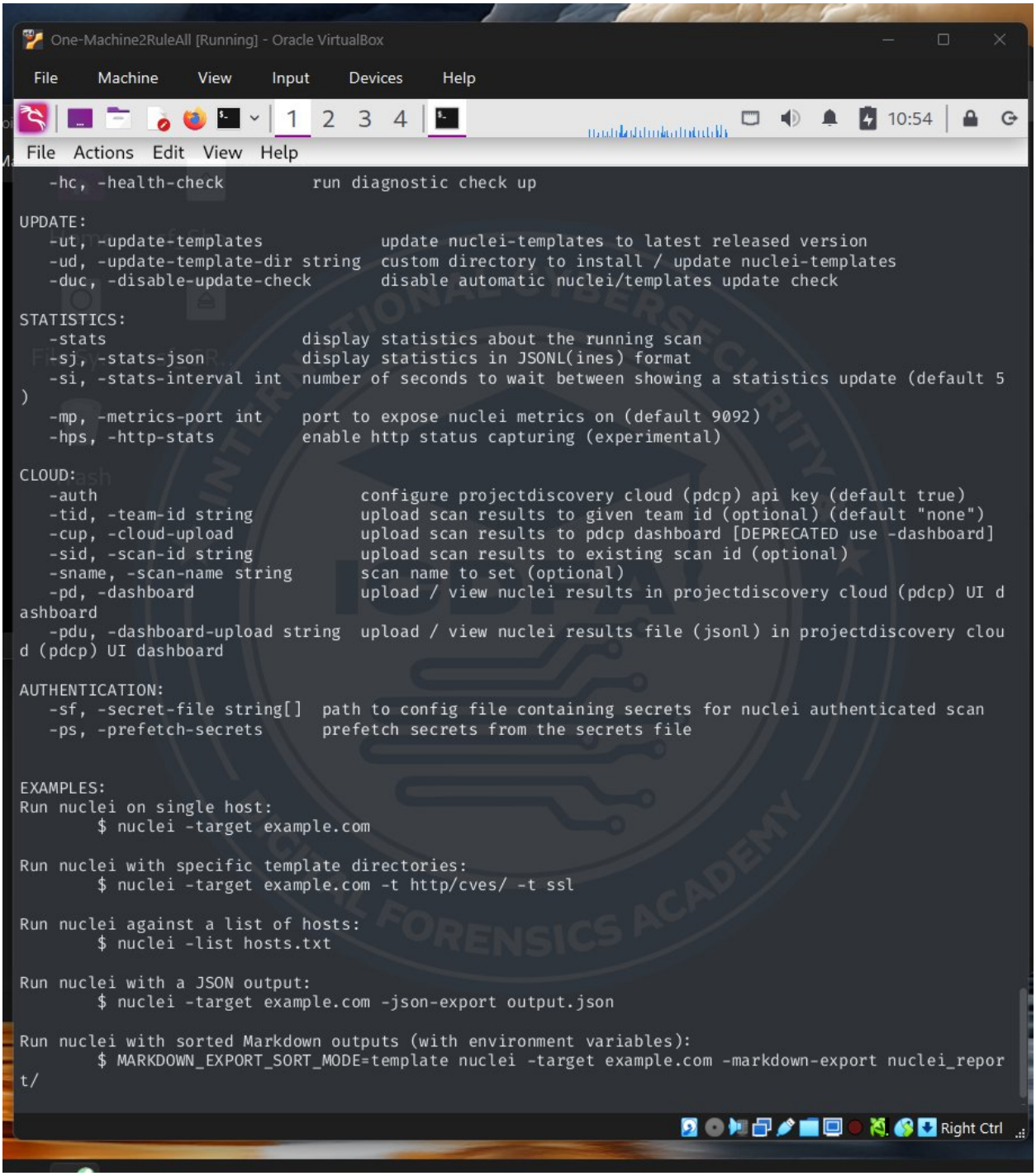

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:31
File Actions Edit View Help
[INF] Your current nuclei-templates are outdated. Latest is v10.4.1
┌──(icdfa㉿icdfa)-[~]
└─$ sudo apt update && sudo apt install nuclei
[sudo] password for icdfa:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 https://artifacts.elastic.co/packages/8.x/apt stable InRelease [3,249 B]
Err:2 https://artifacts.elastic.co/packages/8.x/apt stable InRelease
Sub-process /usr/bin/sqv returned an error code (1), error message is: Signing key on 46095ACC85485
82C1A2699A9D27D666CD88E42B4 is not bound: No binding signature at time 2026-04-08T10:57:45
Z because: Policy rejected non-revocation signature (PositiveCertification) requiring second pre-im
age resistance because: SHA1 is not considered secure since 2026-01-01T00:00:00Z
Get:3 http://kali.download/kali kali-rolling/main i386 Packages [20.6 MB]
Get:4 http://kali.download/kali kali-rolling/main amd64 Packages [21.1 MB]
Get:5 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.5 MB]
Ign:5 http://kali.download/kali kali-rolling/main amd64 Contents (deb)
Ign:6 http://kali.download/kali kali-rolling/main i386 Contents (deb)
Ign:7 http://kali.download/kali kali-rolling/contrib i386 Packages
Ign:8 http://kali.download/kali kali-rolling/contrib amd64 Packages
Ign:9 http://kali.download/kali kali-rolling/contrib i386 Contents (deb)
Ign:10 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb)
Ign:11 http://kali.download/kali kali-rolling/non-free i386 Packages
Ign:12 http://kali.download/kali kali-rolling/non-free amd64 Packages
Ign:13 http://kali.download/kali kali-rolling/non-free i386 Contents (deb)
Ign:14 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb)
Ign:15 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages
Ign:5 http://kali.download/kali kali-rolling/main amd64 Contents (deb)
Ign:6 http://kali.download/kali kali-rolling/main i386 Contents (deb)
Ign:7 http://http.kali.org/kali kali-rolling/contrib i386 Packages
Err:8 http://http.kali.org/kali kali-rolling/contrib amd64 Packages
Cannot initiate the connection to kali.download:80 (2606:4700::6811:feef). - connect (101: Network
is unreachable) Cannot initiate the connection to kali.download:80 (2606:4700::6811:fdef). - connect
(101: Network is unreachable) [IP: 104.17.254.239 80]
Cannot initiate the connection to http.kali.org:80 (2607:5300:203:3fe6::). - connect (101: Network
is unreachable) [IP: 54.39.128.230 80]
Ign:9 http://http.kali.org/kali kali-rolling/contrib i386 Contents (deb)
Ign:10 http://http.kali.org/kali kali-rolling/contrib amd64 Contents (deb)
Ign:11 http://http.kali.org/kali kali-rolling/non-free i386 Packages
Ign:12 http://http.kali.org/kali kali-rolling/non-free amd64 Packages
Ign:13 http://http.kali.org/kali kali-rolling/non-free i386 Contents (deb)
Ign:14 http://http.kali.org/kali kali-rolling/non-free amd64 Contents (deb)
Ign:15 http://http.kali.org/kali kali-rolling/non-free-firmware amd64 Packages
Ign:5 http://http.kali.org/kali kali-rolling/main amd64 Contents (deb)
Ign:6 http://http.kali.org/kali kali-rolling/main i386 Contents (deb)
Ign:8 http://kali.download/kali kali-rolling/contrib amd64 Packages
Ign:9 http://kali.download/kali kali-rolling/contrib i386 Contents (deb)
Ign:10 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb)
Right Ctrl

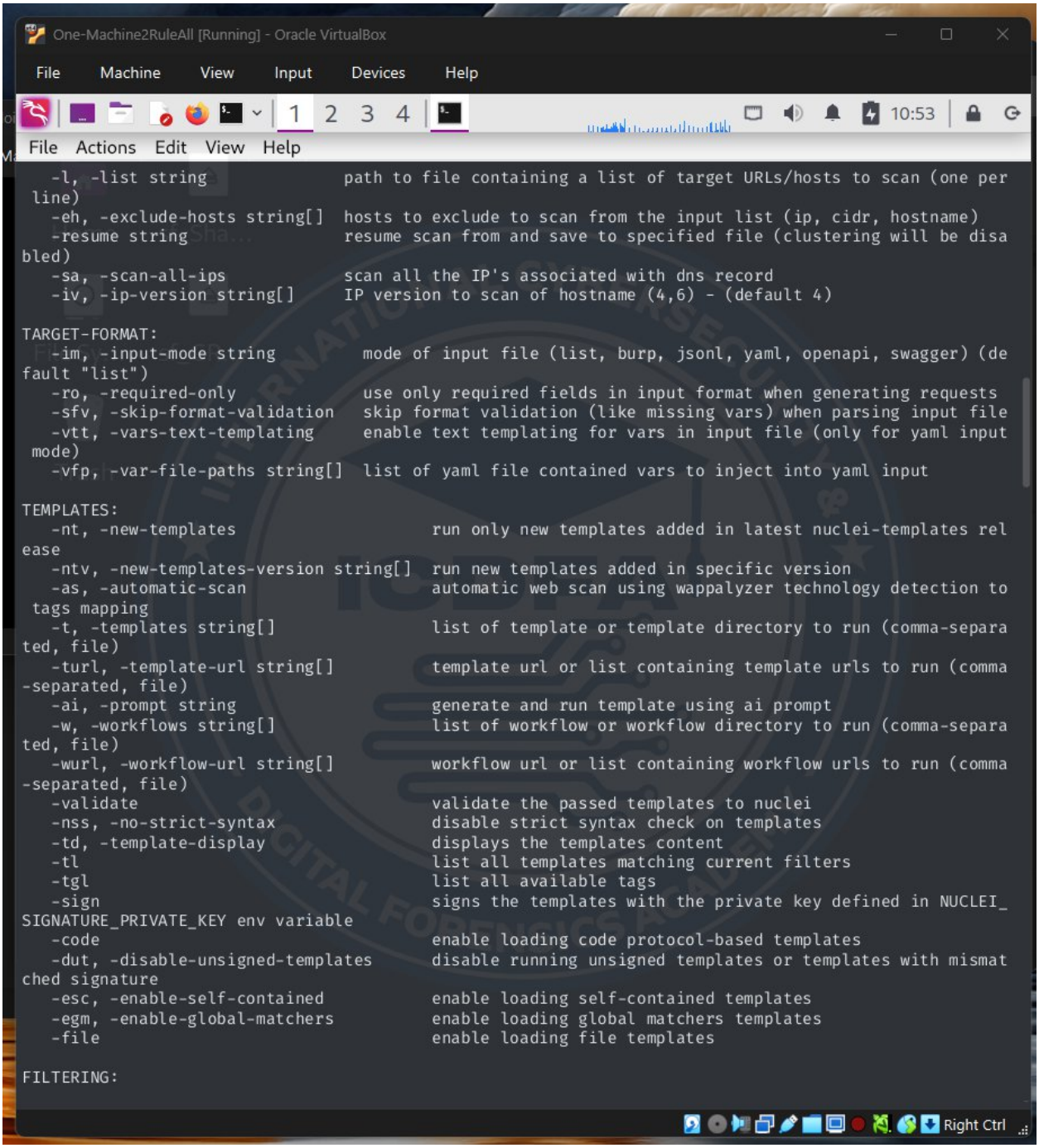

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
18:47
File Actions Edit View Help
icdfa@icdfa: ~/grc-lab-week1/task1
icdfa@icdfa: ~/grc-lab-week1/task2
rg/en-US/docs/Web/HTTP/CSP:
+ GET /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla
.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security:
+ BAKRJDYE /: Web Server returns a valid response with junk HTTP methods which may cause false positi
ves.
+ TRACE /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See:
https://owasp.org/www-community/attacks/Cross_Site_Tracing:
+ GET /phpinfo.php: Output from the phpinfo() function was found.
+ GET /doc/: Directory indexing found.
+ GET /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: CVE-1999-0678:
+ GET /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive infor
mation via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeup
s/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive inform
ation via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups
/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive inform
ation via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups
/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive inform
ation via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups
/do-you-dare-to-show-your-php-easter-egg/:
+ GET /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected
or limited to authorized hosts.
+ GET /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/Cha
ngeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 18:24:00 2008. See: CVE-2003-1418:
+ GET /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or l
imited to authorized hosts.
+ GET /test/: Directory indexing found.
+ GET /test/: This might be interesting.
+ GET /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a
lot of system information. See: CWE-552:
+ GET /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-acce
ss-to-iconsreadme/:
+ GET /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limi
ted to authorized hosts. See: https://typo3.org/:
+ GET /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP
header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Ref
erence/Headers/X-Frame-Options:
+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the
content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vuln
erability-scanner/vulnerabilities/missing-content-type-header/:
(icdfa㉿icdfa)-[~/grc-lab-week1/task1]
$ cat nuclei_web_scan.txt
Right Ctrl

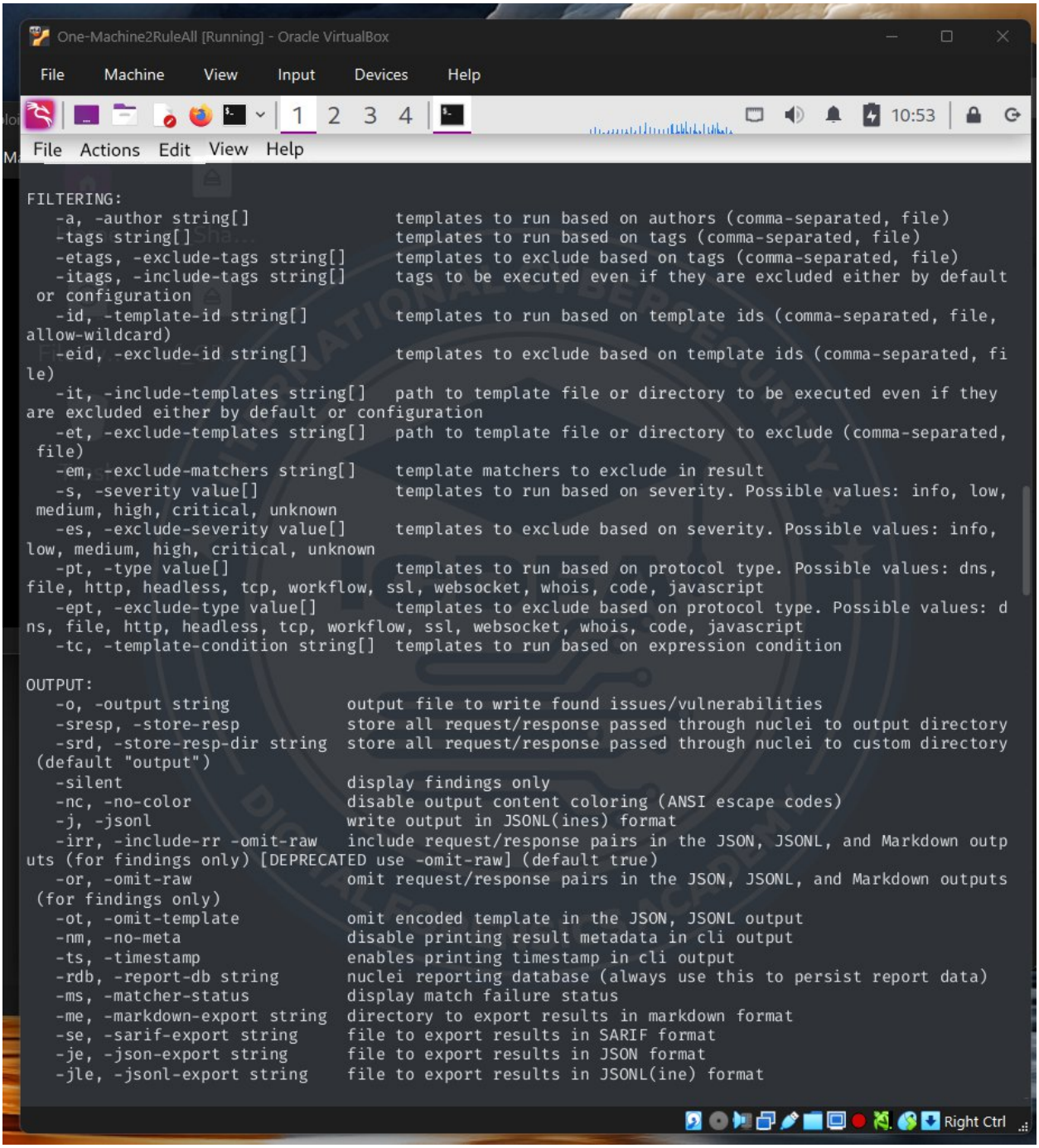

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:30
File Actions Edit View Help
[INF] nuclei-templates are not installed, installing...
[INF] Your current nuclei-templates are outdated. Latest is v10.4.1
┌──(icdfa㉿icdfa)-[~]
└─$ rm -rf ~/.local/nuclei-templates
┌──(icdfa㉿icdfa)-[~]
└─$ nuclei -reset
Using '-reset' will delete all nuclei configurations files and all nuclei-templates
Following files will be deleted:
1. All Config + Resumes files at /home/icdfa/.config/nuclei
2. All nuclei-templates at /home/icdfa/.local/nuclei-templates
Note: Make sure you have backup of your custom nuclei-templates before proceeding
Are you sure you want to continue? [y/n]: y
[INF] Successfully deleted all nuclei configurations files and nuclei-templates
┌──(icdfa㉿icdfa)-[~]
└─$ nuclei -update-templates -force-update
flag provided but not defined: -force-update
┌──(icdfa㉿icdfa)-[~]
└─$ rm -rf ~/.local/nuclei-templates
┌──(icdfa㉿icdfa)-[~]
└─$ nuclei -reset
Using '-reset' will delete all nuclei configurations files and all nuclei-templates
Following files will be deleted:
1. All Config + Resumes files at /home/icdfa/.config/nuclei
2. All nuclei-templates at /home/icdfa/.local/nuclei-templates
Note: Make sure you have backup of your custom nuclei-templates before proceeding
Are you sure you want to continue? [y/n]: Y
[INF] Successfully deleted all nuclei configurations files and nuclei-templates
┌──(icdfa㉿icdfa)-[~]
└─$ nuclei -update-templates
Right Ctrl

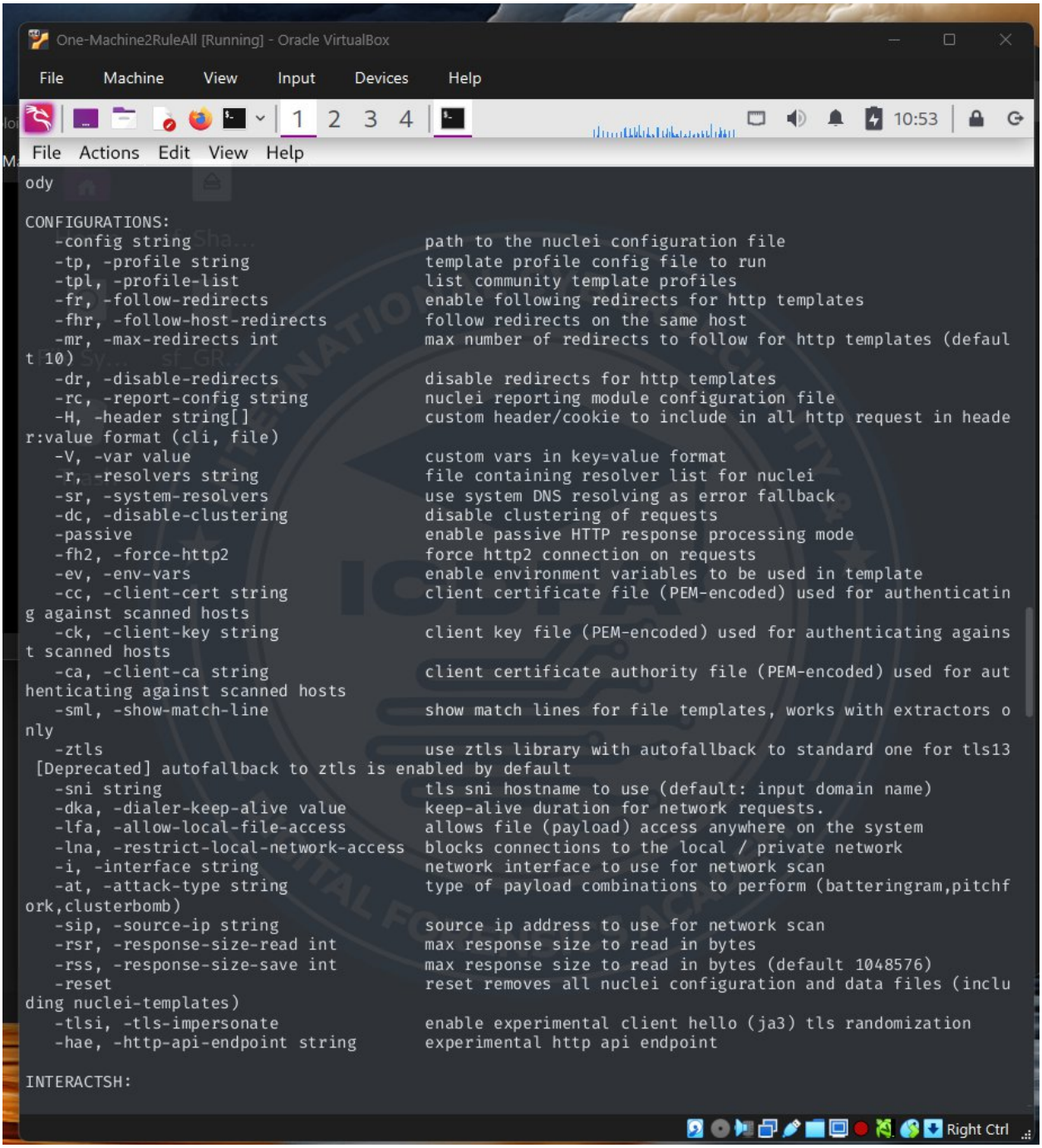

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:51
File Actions Edit View Help
┌──(icdfa㉿icdfa)-[~]
└─$ nikto -h http://192.168.43.225 -o nikto_scan.txt
- Nikto v2.6.0
+ Your Nikto installation is out of date.
+ Target IP: 192.168.43.225
+ Target Hostname: 192.168.43.225
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-04-11 10:43:38 (GMT1)
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive i
Right Ctrl

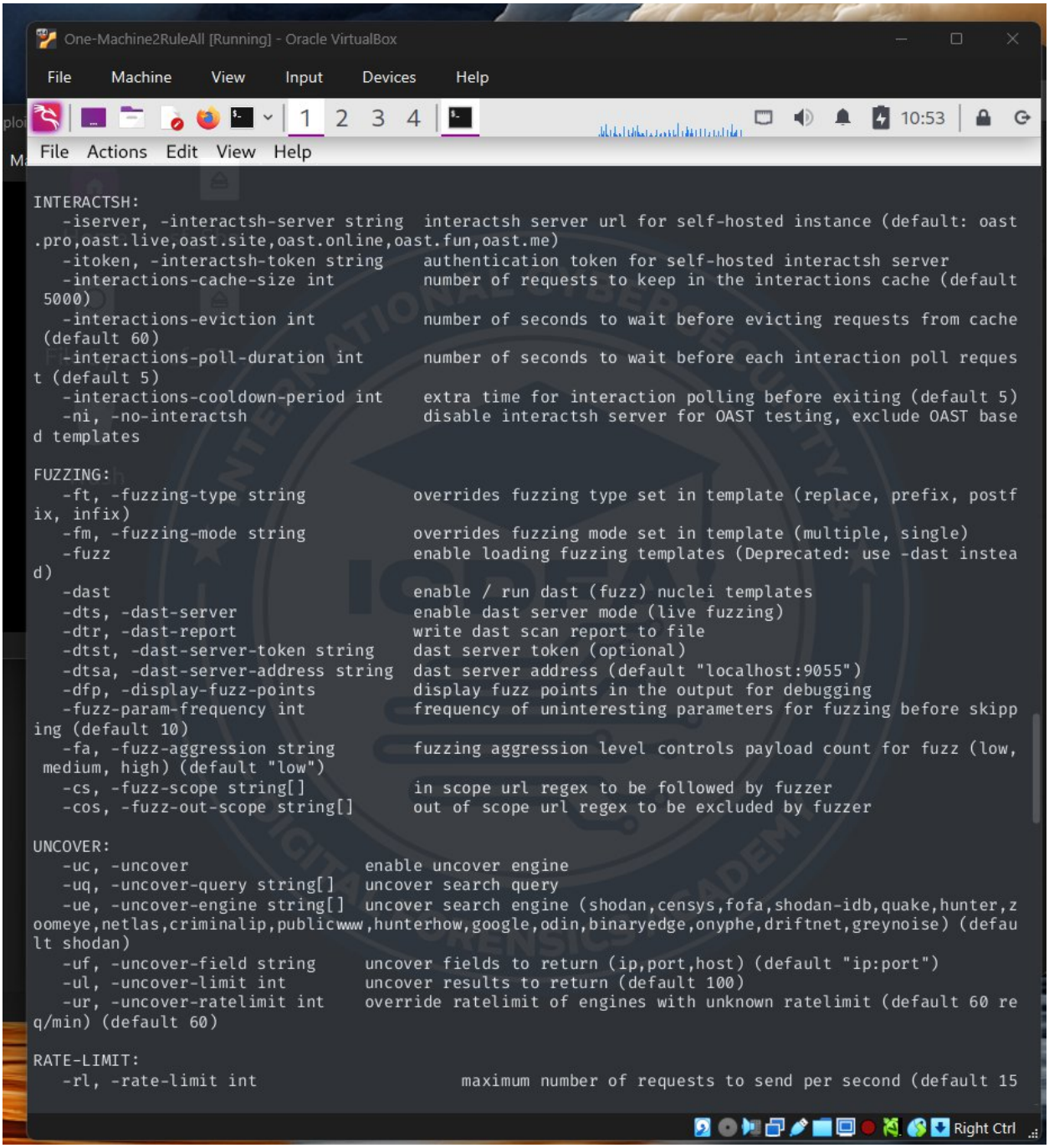

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:53
File Actions Edit View Help
nformation via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 18:24:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8242 requests: 16 errors and 30 items reported on the remote host
+ End Time: 2026-04-11 10:49:25 (GMT1) (347 seconds)
+ 1 host(s) tested
┌──(icdfa㉿icdfa)-[~]
└─$ nuclei -h http://192.168.43.225 -o nuclei_web_scan.txt
Nuclei is a fast, template based vulnerability scanner focusing
on extensive configurability, massive extensibility and ease of use.
Usage:
nuclei [flags]
Flags:
TARGET:
-u, -target string[] target URLs/hosts to scan
-l, -list string path to file containing a list of target URLs/hosts to scan (one per line)
-eh, -exclude-hosts string[] hosts to exclude to scan from the input list (ip, cidr, hostname)
-resume string resume scan from and save to specified file (clustering will be disabled)
Right Ctrl

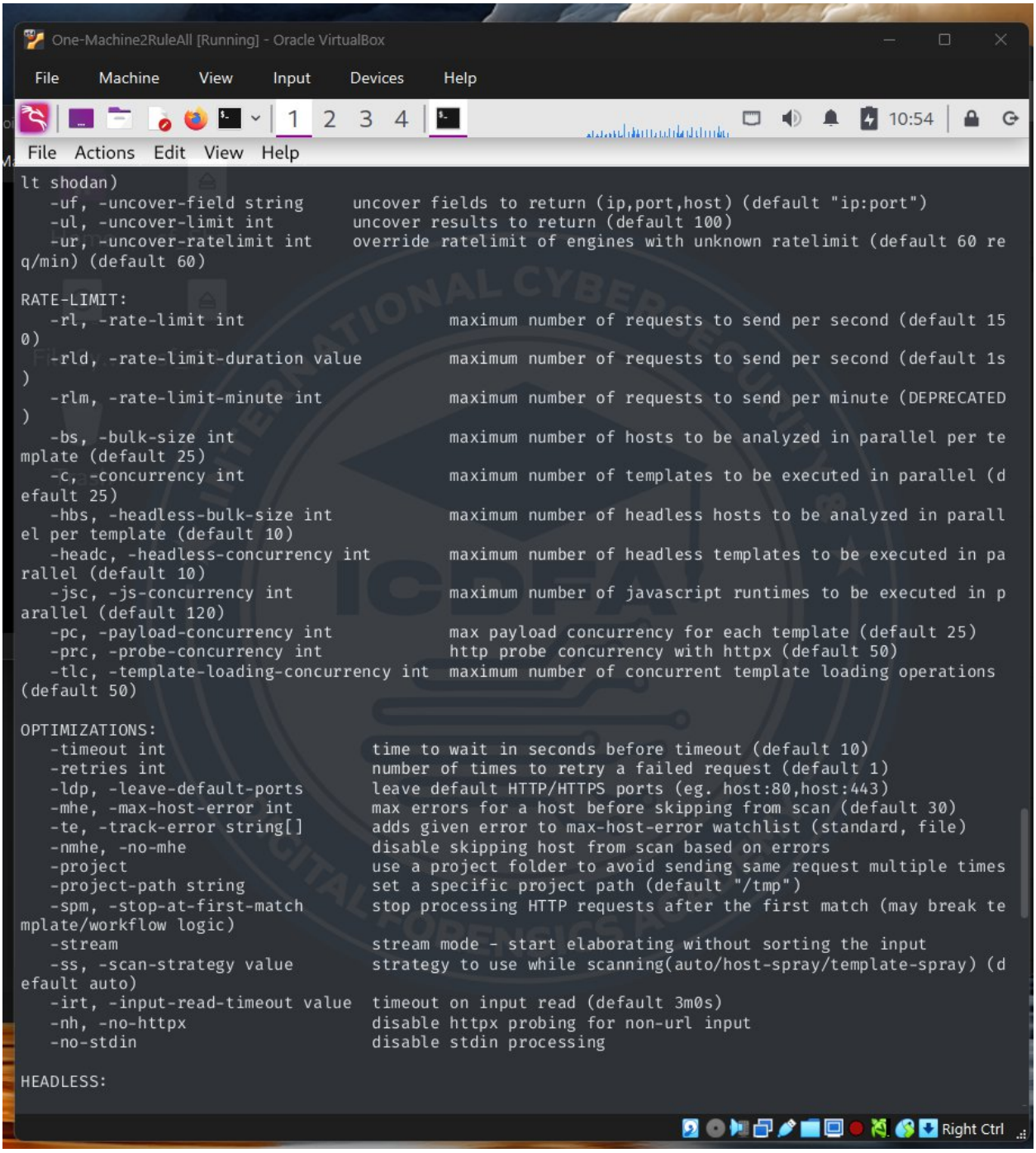

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:54
File Actions Edit View Help
-hc, -health-check run diagnostic check up
UPDATE:
-ut, -update-templates update nuclei-templates to latest released version
-ud, -update-template-dir string custom directory to install / update nuclei-templates
-duc, -disable-update-check disable automatic nuclei/templates update check
STATISTICS:
-stats display statistics about the running scan
-sj, -stats-json display statistics in JSONL(ines) format
-si, -stats-interval int number of seconds to wait between showing a statistics update (default 5)
-mp, -metrics-port int port to expose nuclei metrics on (default 9092)
-hps, -http-stats enable http status capturing (experimental)
CLOUD:
-auth configure projectdiscovery cloud (pdcp) api key (default true)
-tid, -team-id string upload scan results to given team id (optional) (default "none")
-cup, -cloud-upload upload scan results to pdcp dashboard [DEPRECATED use -dashboard]
-sid, -scan-id string upload scan results to existing scan id (optional)
-sname, -scan-name string scan name to set (optional)
-pd, -dashboard upload / view nuclei results in projectdiscovery cloud (pdcp) UI dashboard
-pdu, -dashboard-upload string upload / view nuclei results file (jsonl) in projectdiscovery cloud (pdcp) UI dashboard
AUTHENTICATION:
-sf, -secret-file string[] path to config file containing secrets for nuclei authenticated scan
-ps, -prefetch-secrets prefetch secrets from the secrets file
EXAMPLES:
Run nuclei on single host:
$ nuclei -target example.com
Run nuclei with specific template directories:
$ nuclei -target example.com -t http/cves/ -t ssl
Run nuclei against a list of hosts:
$ nuclei -list hosts.txt
Run nuclei with a JSON output:
$ nuclei -target example.com -json-export output.json
Run nuclei with sorted Markdown outputs (with environment variables):
$ MARKDOWN_EXPORT_SORT_MODE=template nuclei -target example.com -markdown-export nuclei_report/
Right Ctrl

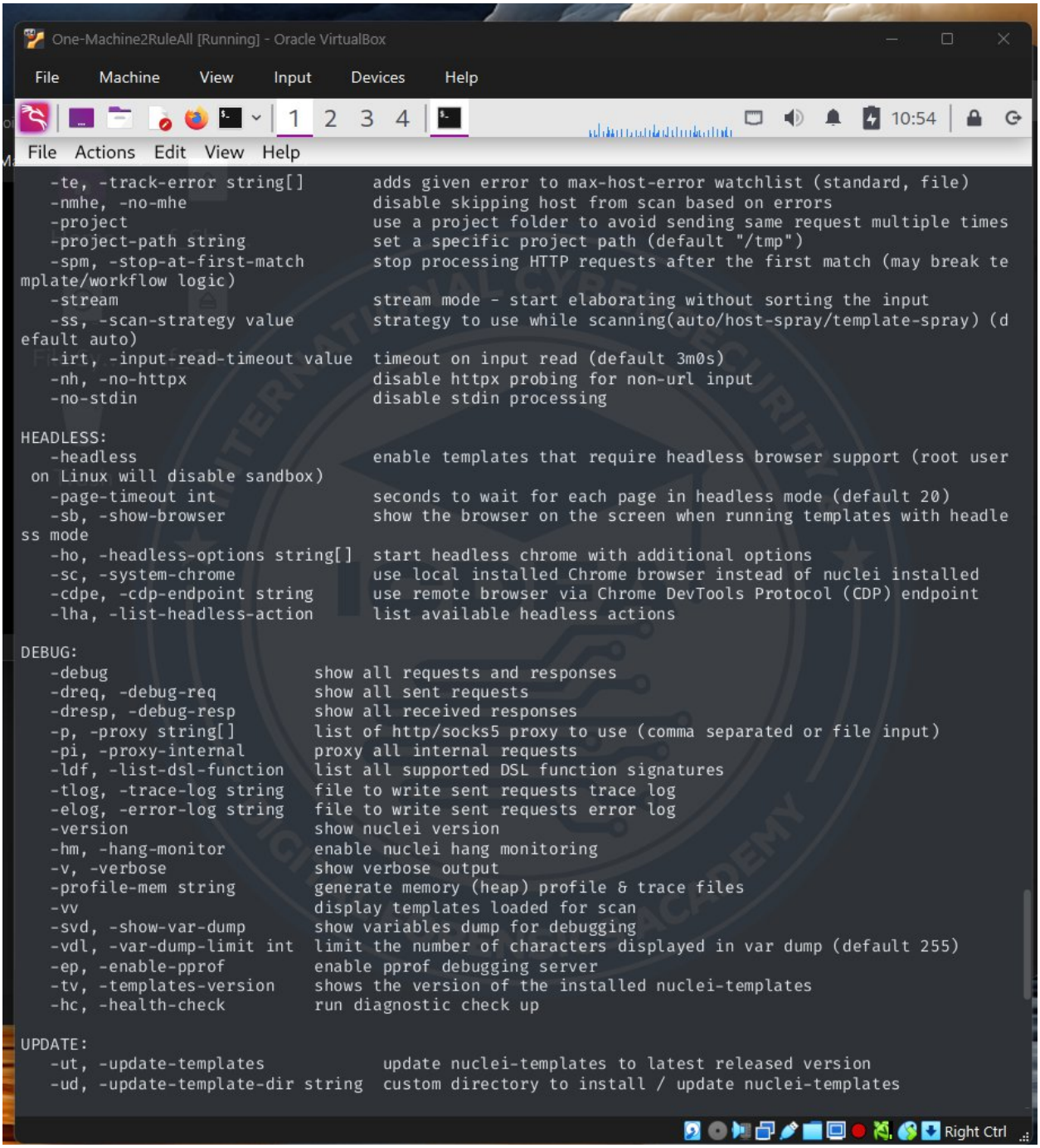

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:53
File Actions Edit View Help
-l, -list string path to file containing a list of target URLs/hosts to scan (one per line)
-eh, -exclude-hosts string[] hosts to exclude to scan from the input list (ip, cidr, hostname)
-resume string resume scan from and save to specified file (clustering will be disabled)
-sa, -scan-all-ips scan all the IP's associated with dns record
-iv, -ip-version string[] IP version to scan of hostname (4,6) - (default 4)
TARGET-FORMAT:
-im, -input-mode string mode of input file (list, burp, jsonl, yaml, openapi, swagger) (default "list")
-ro, -required-only use only required fields in input format when generating requests
-sfv, -skip-format-validation skip format validation (like missing vars) when parsing input file
-vtt, -vars-text-templating enable text templating for vars in input file (only for yaml input mode)
-vfp, -var-file-paths string[] list of yaml file contained vars to inject into yaml input
TEMPLATES:
-nt, -new-templates run only new templates added in latest nuclei-templates release
-ntv, -new-templates-version string[] run new templates added in specific version
-as, -automatic-scan automatic web scan using wappalyzer technology detection to tags mapping
-t, -templates string[] list of template or template directory to run (comma-separated, file)
-turl, -template-url string[] template url or list containing template urls to run (comma-separated, file)
-ai, -prompt string generate and run template using ai prompt
-w, -workflows string[] list of workflow or workflow directory to run (comma-separated, file)
-wurl, -workflow-url string[] workflow url or list containing workflow urls to run (comma-separated, file)
-validate validate the passed templates to nuclei
-nss, -no-strict-syntax disable strict syntax check on templates
-td, -template-display displays the templates content
-tl list all templates matching current filters
-tgl list all available tags
-sign signs the templates with the private key defined in NUCLEI_SIGNATURE_PRIVATE_KEY env variable
-code enable loading code protocol-based templates
-dut, -disable-unsigned-templates disable running unsigned templates or templates with mismatched signature
-esc, -enable-self-contained enable loading self-contained templates
-egm, -enable-global-matchers enable loading global matchers templates
-file enable loading file templates
FILTERING:
Right Ctrl

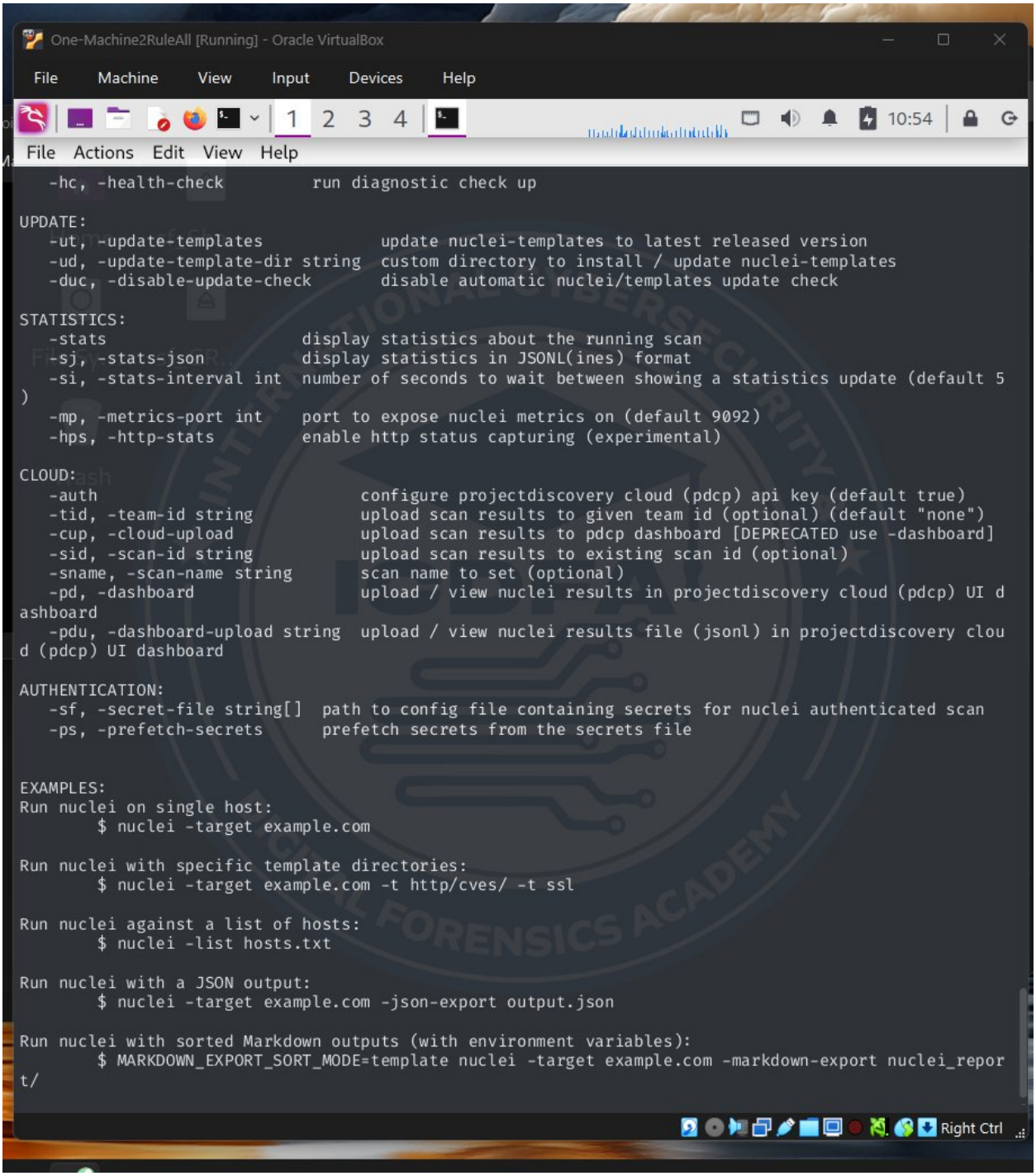

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:53
File Actions Edit View Help
FILTERING:
-a, -author string[] templates to run based on authors (comma-separated, file)
-tags string[] templates to run based on tags (comma-separated, file)
-etags, -exclude-tags string[] templates to exclude based on tags (comma-separated, file)
-itags, -include-tags string[] tags to be executed even if they are excluded either by default or configuration
-id, -template-id string[] templates to run based on template ids (comma-separated, file, allow-wildcard)
-eid, -exclude-id string[] templates to exclude based on template ids (comma-separated, file)
-it, -include-templates string[] path to template file or directory to be executed even if they are excluded either by default or configuration
-et, -exclude-templates string[] path to template file or directory to exclude (comma-separated, file)
-em, -exclude-matchers string[] template matchers to exclude in result
-s, -severity value[] templates to run based on severity. Possible values: info, low, medium, high, critical, unknown
-es, -exclude-severity value[] templates to exclude based on severity. Possible values: info, low, medium, high, critical, unknown
-pt, -type value[] templates to run based on protocol type. Possible values: dns, file, http, headless, tcp, workflow, ssl, websocket, whois, code, javascript
-ept, -exclude-type value[] templates to exclude based on protocol type. Possible values: dns, file, http, headless, tcp, workflow, ssl, websocket, whois, code, javascript
-tc, -template-condition string[] templates to run based on expression condition
OUTPUT:
-o, -output string output file to write found issues/vulnerabilities
-sresp, -store-resp store all request/response passed through nuclei to output directory
-srd, -store-resp-dir string store all request/response passed through nuclei to custom directory (default "output")
-silent display findings only
-nc, -no-color disable output content coloring (ANSI escape codes)
-j, -jsonl write output in JSONL(ines) format
-irr, -include-rr -omit-raw include request/response pairs in the JSON, JSONL, and Markdown outputs (for findings only) [DEPRECATED use -omit-raw] (default true)
-or, -omit-raw omit request/response pairs in the JSON, JSONL, and Markdown outputs (for findings only)
-ot, -omit-template omit encoded template in the JSON, JSONL output
-nm, -no-meta disable printing result metadata in cli output
-ts, -timestamp enables printing timestamp in cli output
-rdb, -report-db string nuclei reporting database (always use this to persist report data)
-ms, -matcher-status display match failure status
-me, -markdown-export string directory to export results in markdown format
-se, -sarif-export string file to export results in SARIF format
-je, -json-export string file to export results in JSON format
-jle, -jsonl-export string file to export results in JSONL(ine) format
Right Ctrl

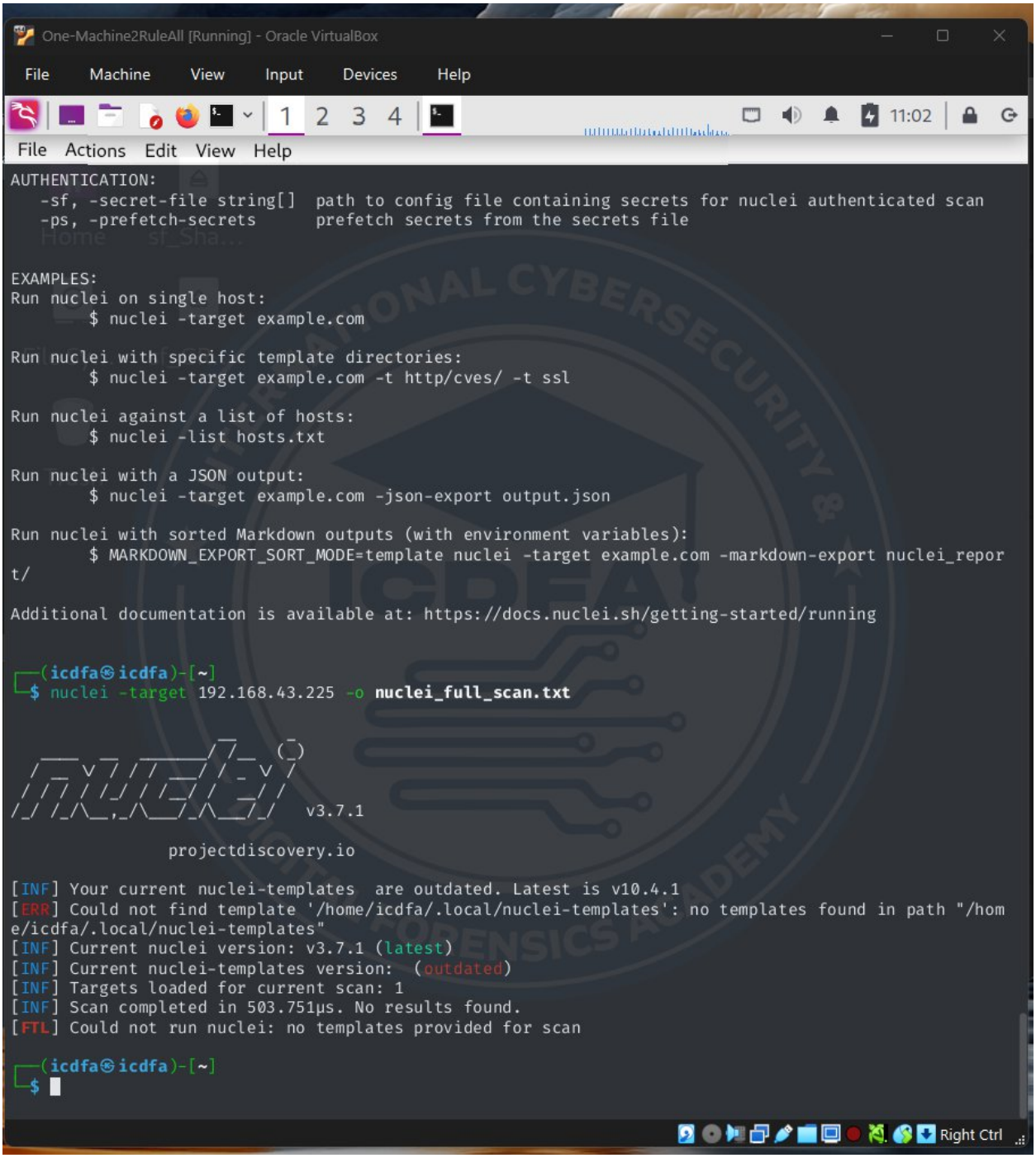

One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:53
File Actions Edit View Help
ody
CONFIGURATIONS:
-config string path to the nuclei configuration file
-tp, -profile string template profile config file to run
-tpl, -profile-list list community template profiles
-fr, -follow-redirects enable following redirects for http templates
-fhr, -follow-host-redirects follow redirects on the same host
-mr, -max-redirects int max number of redirects to follow for http templates (defaul
t 10)
-dr, -disable-redirects disable redirects for http templates
-rc, -report-config string nuclei reporting module configuration file
-H, -header string[] custom header/cookie to include in all http request in heade
r:value format (cli, file)
-V, -var value custom vars in key=value format
-r, -resolvers string file containing resolver list for nuclei
-sr, -system-resolvers use system DNS resolving as error fallback
-dc, -disable-clustering disable clustering of requests
-passive enable passive HTTP response processing mode
-fh2, -force-http2 force http2 connection on requests
-ev, -env-vars enable environment variables to be used in template
-cc, -client-cert string client certificate file (PEM-encoded) used for authenticatin
g against scanned hosts
-ck, -client-key string client key file (PEM-encoded) used for authenticating agains
t scanned hosts
-ca, -client-ca string client certificate authority file (PEM-encoded) used for aut
henticating against scanned hosts
-sml, -show-match-line show match lines for file templates, works with extractors o
nly
-ztls use ztls library with autofallback to standard one for tls13
[Deprecated] autofallback to ztls is enabled by default
-sni string tls sni hostname to use (default: input domain name)
-dka, -dialer-keep-alive value keep-alive duration for network requests.
-lfa, -allow-local-file-access allows file (payload) access anywhere on the system
-lna, -restrict-local-network-access blocks connections to the local / private network
-i, -interface string network interface to use for network scan
-at, -attack-type string type of payload combinations to perform (batteringram,pitchf
ork,clusterbomb)
-sip, -source-ip string source ip address to use for network scan
-rsr, -response-size-read int max response size to read in bytes
-rss, -response-size-save int max response size to read in bytes (default 1048576)
-reset reset removes all nuclei configuration and data files (inclu
ding nuclei-templates)
-tlsi, -tls-impersonate enable experimental client hello (ja3) tls randomization
-hae, -http-api-endpoint string experimental http api endpoint
INTERACTSH:
Right Ctrl


One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:53
File Actions Edit View Help
INTERACTSH:
-iserver, -interactsh-server string interactsh server url for self-hosted instance (default: oast.pro,oast.live,oast.site,oast.online,oast.fun,oast.me)
-itoken, -interactsh-token string authentication token for self-hosted interactsh server
-interactions-cache-size int number of requests to keep in the interactions cache (default 5000)
-interactions-eviction int number of seconds to wait before evicting requests from cache (default 60)
-interactions-poll-duration int number of seconds to wait before each interaction poll request (default 5)
-interactions-cooldown-period int extra time for interaction polling before exiting (default 5)
-ni, -no-interactsh disable interactsh server for OAST testing, exclude OAST based templates
FUZZING:
-ft, -fuzzing-type string overrides fuzzing type set in template (replace, prefix, postfix, infix)
-fm, -fuzzing-mode string overrides fuzzing mode set in template (multiple, single)
-fuzz enable loading fuzzing templates (Deprecated: use -dast instead)
-dast enable / run dast (fuzz) nuclei templates
-dts, -dast-server enable dast server mode (live fuzzing)
-dtr, -dast-report write dast scan report to file
-dtst, -dast-server-token string dast server token (optional)
-dtsa, -dast-server-address string dast server address (default "localhost:9055")
-dfp, -display-fuzz-points display fuzz points in the output for debugging
-fuzz-param-frequency int frequency of uninteresting parameters for fuzzing before skipping (default 10)
-fa, -fuzz-aggression string fuzzing aggression level controls payload count for fuzz (low, medium, high) (default "low")
-cs, -fuzz-scope string[] in scope url regex to be followed by fuzzer
-cos, -fuzz-out-scope string[] out of scope url regex to be excluded by fuzzer
UNCOVER:
-uc, -uncover enable uncover engine
-uq, -uncover-query string[] uncover search query
-ue, -uncover-engine string[] uncover search engine (shodan,censys,fofa,shodan-idb,quake,hunter,zoomeye,netlas,criminalip,publicwww,hunterhow,google,odin,binaryedge,onyphe,driftnet,greynoise) (default shodan)
-uf, -uncover-field string uncover fields to return (ip,port,host) (default "ip:port")
-ul, -uncover-limit int uncover results to return (default 100)
-ur, -uncover-ratelimit int override ratelimit of engines with unknown ratelimit (default 60 req/min) (default 60)
RATE-LIMIT:
-rl, -rate-limit int maximum number of requests to send per second (default 15
Right Ctrl


One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:54
File Actions Edit View Help
lt shodan)
-uf, -uncover-field string uncover fields to return (ip,port,host) (default "ip:port")
-ul, -uncover-limit int uncover results to return (default 100)
-ur, -uncover-ratelimit int override ratelimit of engines with unknown ratelimit (default 60 req/min) (default 60)
RATE-LIMIT:
-rl, -rate-limit int maximum number of requests to send per second (default 150)
-rld, -rate-limit-duration value maximum number of requests to send per second (default 1s)
-rlm, -rate-limit-minute int maximum number of requests to send per minute (DEPRECATED)
-bs, -bulk-size int maximum number of hosts to be analyzed in parallel per template (default 25)
-c, -concurrency int maximum number of templates to be executed in parallel (default 25)
-hbs, -headless-bulk-size int maximum number of headless hosts to be analyzed in parallel per template (default 10)
-headc, -headless-concurrency int maximum number of headless templates to be executed in parallel (default 10)
-jsc, -js-concurrency int maximum number of javascript runtimes to be executed in parallel (default 120)
-pc, -payload-concurrency int max payload concurrency for each template (default 25)
-prc, -probe-concurrency int http probe concurrency with httpx (default 50)
-tlc, -template-loading-concurrency int maximum number of concurrent template loading operations (default 50)
OPTIMIZATIONS:
-timeout int time to wait in seconds before timeout (default 10)
-retries int number of times to retry a failed request (default 1)
-ldp, -leave-default-ports leave default HTTP/HTTPS ports (eg. host:80,host:443)
-mhe, -max-host-error int max errors for a host before skipping from scan (default 30)
-te, -track-error string[] adds given error to max-host-error watchlist (standard, file)
-nmhe, -no-mhe disable skipping host from scan based on errors
-project use a project folder to avoid sending same request multiple times
-project-path string set a specific project path (default "/tmp")
-spm, -stop-at-first-match stop processing HTTP requests after the first match (may break template/workflow logic)
-stream stream mode - start elaborating without sorting the input
-ss, -scan-strategy value strategy to use while scanning(auto/host-spray/template-spray) (default auto)
-irt, -input-read-timeout value timeout on input read (default 3m0s)
-nh, -no-httpx disable httpx probing for non-url input
-no-stdin disable stdin processing
HEADLESS:
Right Ctrl


One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:54
File Actions Edit View Help
-te, -track-error string[] adds given error to max-host-error watchlist (standard, file)
-nmhe, -no-mhe disable skipping host from scan based on errors
-project use a project folder to avoid sending same request multiple times
-project-path string set a specific project path (default "/tmp")
-spm, -stop-at-first-match stop processing HTTP requests after the first match (may break template/workflow logic)
-stream stream mode - start elaborating without sorting the input
-ss, -scan-strategy value strategy to use while scanning(auto/host-spray/template-spray) (default auto)
-irt, -input-read-timeout value timeout on input read (default 3m0s)
-nh, -no-httpx disable httpx probing for non-url input
-no-stdin disable stdin processing
HEADLESS:
-headless enable templates that require headless browser support (root user on Linux will disable sandbox)
-page-timeout int seconds to wait for each page in headless mode (default 20)
-sb, -show-browser show the browser on the screen when running templates with headless mode
-ho, -headless-options string[] start headless chrome with additional options
-sc, -system-chrome use local installed Chrome browser instead of nuclei installed
-cdpe, -cdp-endpoint string use remote browser via Chrome DevTools Protocol (CDP) endpoint
-lha, -list-headless-action list available headless actions
DEBUG:
-debug show all requests and responses
-dreq, -debug-req show all sent requests
-dresp, -debug-resp show all received responses
-p, -proxy string[] list of http/socks5 proxy to use (comma separated or file input)
-pi, -proxy-internal proxy all internal requests
-ldf, -list-dsl-function list all supported DSL function signatures
-tlog, -trace-log string file to write sent requests trace log
-elog, -error-log string file to write sent requests error log
-version show nuclei version
-hm, -hang-monitor enable nuclei hang monitoring
-v, -verbose show verbose output
-profile-mem string generate memory (heap) profile & trace files
-vv display templates loaded for scan
-svd, -show-var-dump show variables dump for debugging
-vdl, -var-dump-limit int limit the number of characters displayed in var dump (default 255)
-ep, -enable-pprof enable pprof debugging server
-tv, -templates-version shows the version of the installed nuclei-templates
-hc, -health-check run diagnostic check up
UPDATE:
-ut, -update-templates update nuclei-templates to latest released version
-ud, -update-template-dir string custom directory to install / update nuclei-templates
Right Ctrl


One-Machine2RuleAll [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
10:54
File Actions Edit View Help
-hc, -health-check run diagnostic check up
UPDATE:
-ut, -update-templates update nuclei-templates to latest released version
-ud, -update-template-dir string custom directory to install / update nuclei-templates
-duc, -disable-update-check disable automatic nuclei/templates update check
STATISTICS:
-stats display statistics about the running scan
-sj, -stats-json display statistics in JSONL(ines) format
-si, -stats-interval int number of seconds to wait between showing a statistics update (default 5)
-mp, -metrics-port int port to expose nuclei metrics on (default 9092)
-hps, -http-stats enable http status capturing (experimental)
CLOUD:
-auth configure projectdiscovery cloud (pdcp) api key (default true)
-tid, -team-id string upload scan results to given team id (optional) (default "none")
-cup, -cloud-upload upload scan results to pdcp dashboard [DEPRECATED use -dashboard]
-sid, -scan-id string upload scan results to existing scan id (optional)
-sname, -scan-name string scan name to set (optional)
-pd, -dashboard upload / view nuclei results in projectdiscovery cloud (pdcp) UI dashboard
-pdu, -dashboard-upload string upload / view nuclei results file (jsonl) in projectdiscovery cloud (pdcp) UI dashboard
AUTHENTICATION:
-sf, -secret-file string[] path to config file containing secrets for nuclei authenticated scan
-ps, -prefetch-secrets prefetch secrets from the secrets file
EXAMPLES:
Run nuclei on single host:
$ nuclei -target example.com
Run nuclei with specific template directories:
$ nuclei -target example.com -t http/cves/ -t ssl
Run nuclei against a list of hosts:
$ nuclei -list hosts.txt
Run nuclei with a JSON output:
$ nuclei -target example.com -json-export output.json
Run nuclei with sorted Markdown outputs (with environment variables):
$ MARKDOWN_EXPORT_SORT_MODE=template nuclei -target example.com -markdown-export nuclei_report/
Right Ctrl



PHASE 3: Analysis and Reporting (The Core GRC Task)

1. Completed Risk Assessment Table

Finding	Affected Service	CVE/Reference	Inherent Risk	Compliance Violation	Business Impact
vsFTPd 2.3.4 Backdoor	FTP	CVE-2011-2523	**H**	CIS 7.1, NIST CSF PR.IP-1	Full remote system compromise

Weak/Default Credentials	SSH, FTP	N/A	**H**	CIS 5.2, NIST CSF PR.AC-1	Unauthorized access & data theft
Unencrypted Telnet Service	Telnet	N/A	**H**	NIST CSF PR.DS-2	Credential sniffing & espionage
Outdated Apache 2.2.8	HTTP	Multiple	**H**	CIS 7.1, NIST CSF PR.IP-1	Remote code execution & web defacement
Outdated PHP 5.2.4	Web Server	Multiple	**H**	CIS 7.1	Remote code execution
phpMyAdmin Exposed	Web	N/A	**H**	CIS 5.2	Database compromise
Directory Indexing Enabled	Web	N/A	**M**	CIS 5.2	Information disclosure
Missing Security Headers	Web	N/A	**M**	NIST CSF PR.DS-2	Increased XSS & clickjacking risk

2. Executive Summary

To: IT Management
From: GRC Audit Team
Date: 11 April 2026
Subject: High-Risk Vulnerability Assessment and Development Server ‘metasploitable’

1. Executive Summary:

A vulnerability assessment of the internal development server “metasploitable” revealed **multiple critical security vulnerabilities** that present an immediate and severe risk to the organization. The server is significantly non-compliant with CIS Controls and NIST Cybersecurity Framework requirements.

The most critical issues include a known backdoor in vsFTPd (CVE-2011-2523), weak/default credentials, unencrypted legacy services (Telnet/FTP), and severely outdated web components (Apache 2.2.8 + PHP 5.2.4). These findings allow an attacker with low skill level to gain full remote control of the server.

2. Key Findings & Risks

- **Critical Risk**: Remote code execution via vsFTPd backdoor and outdated PHP/Apache.
- **High Risk**: Plaintext credential transmission (Telnet & FTP).
- **High Risk**: Exposed administrative interfaces (phpMyAdmin) and directory indexing.

3. Recommended Actions

1. **Immediate**: Isolate the server from the network.
2. **Short-term**: Patch vsFTPd, disable Telnet/FTP, and remove unnecessary services.
3. **Medium-term**: Upgrade Apache and PHP or decommission the server.
4. **Long-term**: Implement secure baseline configuration and regular vulnerability scanning for all test/development systems.

3. Quantitative Risk Analysis Table (SLE / ALE)

Finding	Asset Value	Exposure Factor	SLE	ARO	ALE
vsFTPd Backdoor	₦50,000,000	100%	₦50M	0.8	**₦40M**
Weak/Default Credentials	₦50,000,000	90%	₦45M	0.9	**₦40.5M**
Unencrypted Telnet/FTP	₦30,000,000	70%	₦21M	0.7	**₦14.7M**
Outdated Apache/PHP	₦40,000,000	85%	₦34M	0.6	**₦20.4M**

4. Risk Treatment Strategy Table

Risk	Treatment	Action Owner	Timeline	Residual Risk
vsFTPd Backdoor	Mitigate	System Admin	24 hours	Low
Weak/Default Credentials	Mitigate	System Admin	48 hours	Low
Unencrypted Services	Avoid	System Admin	Immediate	Low
Outdated Web Stack	Mitigate	Development Team	7 days	Medium

8. NIST 800-53 Control Mapping Table

Finding	NIST 800-53 Control(s)	Control Family	Compliance Status	Recommended Action
vsFTPd 2.3.4 Backdoor	SI-2, CM-8	System & Services	Non-Compliant	Patch / Remove vulnerable service
Weak/Default Credentials	AC-2, AC-3, IA-5	Access Control	Non-Compliant	Enforce strong authentication
Unencrypted Telnet Service	SC-8, SC-17	System & Comm.	Non-Compliant	Disable or encrypt transmission
Outdated Apache 2.2.8 & PHP 5.2.4	SI-2, CM-2	Configuration Mgmt	Non-Compliant	Upgrade or decommission
Exposed phpMyAdmin	AC-3, CM-6	Access Control	Non-Compliant	Restrict access or remove
Directory Indexing Enabled	CM-6, SI-11	Configuration Mgmt	Non-Compliant	Disable directory listing
Missing Security Headers	SC-8, SI-15	System & Comm.	Partial	Implement proper HTTP security headers

9. Business Impact Analysis (BIA) Table

Finding	Asset Affected	Potential Impact	Severity	Maximum Tolerable Downtime	Recovery Priority
vsFTPd Backdoor	Entire Server	Full system compromise & data loss	Critical	4 hours	1 (Immediate)
Weak/Default Credentials	SSH/FTP Access	Unauthorized access & data theft	High	12 hours	2
Unencrypted Telnet Service	Credentials & Sessions	Credential theft & espionage	High	24 hours	3
Outdated Apache & PHP	Web Application	Remote code execution & defacement	High	48 hours	4

Exposed php-MyAdmin	Database	Database compromise & data breach	High	24 hours	3
Directory Indexing	Sensitive Files	Information disclosure	Medium	72 hours	5

Phase 4: Advanced GRC Analysis – Quantitative Risk & Treatment

Step 1: Quantitative Risk Calculation (SLE & ALE)

Risk ID	Asset Name	Threat Description	AV (₦)	EF	SLE (₦)	ARO	ALE (₦)
R1	Development Server	vsFTPd 2.3.4 Backdoor (Remote Code Execution)	80,000,000	100%	80,000,000	0.8	**64,000,000**
R2	Customer & Admin Accounts	Weak/Default Credentials (SSH/FTP)	60,000,000	90%	54,000,000	0.9	**48,600,000**
R3	Sensitive Data in Transit	Unencrypted Telnet Service	45,000,000	70%	31,500,000	0.7	**22,050,000**
R4	Web Application	Outdated Apache 2.2.8 + PHP 5.2.4	70,000,000	85%	59,500,000	0.6	**35,700,000**
R5	Database	Exposed phpMyAdmin	55,000,000	80%	44,000,000	0.5	**22,000,000**

Step 2: Risk Treatment Strategy

Risk ID	Threat Description	ALE (₦)	Proposed Treatment	Justification
R1	vsFTPd Backdoor	64,000,000	**Mitigate**	Apply patch immediately and disable FTP if not required. Highest ALE makes this urgent.
R2	Weak/Default Credentials	48,600,000	**Mitigate**	Enforce strong password policy and SSH key authentication.
R3	Unencrypted Telnet	22,050,000	**Avoid**	Completely disable Telnet; use SSH only.
R4	Outdated Apache/PHP	35,700,000	**Mitigate**	Upgrade or containerize the web stack.
R5	Exposed php-MyAdmin	22,000,000	**Mitigate**	Remove from production or restrict with strong authentication and IP whitelisting.

Step 3: Control Mapping (NIST 800-53)

Risk ID	Threat Description	Proposed Control	NIST 800-53 Control ID	Control Description
R1	vsFTPd Backdoor	Patch Management + Vulnerability Scanning	SI-2, RA-5	Flaw Remediation and Vulnerability Monitoring
R1	vsFTPd Backdoor	Least Functionality	CM-7	Least Functionality
R2	Weak/Default Credentials	Strong Authentication	IA-5, AC-2	Authenticator Management and Account Management

R3	Unencrypted Telnet	Transmission Confidentiality	SC-8	Transmission Confidentiality
R4	Outdated Apache/PHP	Baseline Configuration	CM-2, SI-2	Baseline Configuration and Flaw Remediation
R5	Exposed phpMyAdmin	Boundary Protection	SC-7	Boundary Protection

Phase 5: Business Impact Analysis (BIA) Integration & Final Reporting

Step 1: Business Impact Analysis (BIA) Table

Risk ID	Threat Description	Affected Business Process	RTO	RPO	Financial Impact (per day)	Non-Financial Impact
R1	vsFTPd Backdoor	All operations (full compromise)	4 hours	2 hours	₦8,000,000	Complete data loss, regulatory fines, reputational damage
R2	Weak/Default Credentials	Admin access & customer data	12 hours	4 hours	₦5,000,000	Unauthorized access, data breach, loss of trust
R3	Unencrypted Telnet	Remote administration	24 hours	8 hours	₦2,500,000	Credential theft, espionage
R4	Outdated Apache/PHP	Web-facing applications	48 hours	12 hours	₦4,000,000	Web defacement, customer churn
R5	Exposed phpMyAdmin	Database operations	24 hours	6 hours	₦3,500,000	Database breach, regulatory violation

Step 2: Refined Executive Summary

To: IT Management
From: GRC Audit Team
Date: 11 April 2026
Subject: High-Risk Vulnerability Assessment – Development Server ‘metasploitable’

Executive Summary:
A comprehensive vulnerability assessment of the internal development server “metasploitable” identified **five critical risks** with a combined **Annualized Loss Expectancy (ALE) of ₦192.35 million**.
The highest-risk issue is the vsFTPd 2.3.4 backdoor (ALE ₦64 million), which allows full remote compromise without authentication. Other major risks include weak/default credentials (ALE ₦48.6 million), unencrypted services, and severely outdated web components.

These findings violate multiple CIS Controls and NIST CSF requirements and expose Go-Green to significant financial loss, regulatory fines, and reputational damage.

Recommended Risk Treatment

- **Immediate (0–48 hours)**: Isolate the server and disable Telnet/FTP.
- **Short-term (1 week)**: Patch vsFTPd, enforce strong authentication, and remove exposed phpMyAdmin.
- **Medium-term**: Upgrade or decommission the outdated web stack.

Implementing these controls is expected to reduce the overall ALE by over 85%, delivering a strong Return on Security Investment (ROSI).

References

Center for Internet Security. (2023). *CIS Controls v8*. https://www.cisecurity.org/controls

National Institute of Standards and Technology. (2024). *Cybersecurity Framework 2.0*. https://www.nist.gov/cyberframework

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). https://doi.org/10.6028/NIST.SP.800-53r5

Open Web Application Security Project (OWASP). (2021). *OWASP Top 10: The ten most critical web application security risks*. https://owasp.org/www-project-top-ten/